

Desktop Application Security Audit

Table Of Contents

1 Executive Summary

2 Audit Methodology

3 Project Overview

3.1 Project Introduction

3.2 Vulnerability Information

3.3 Vulnerability Summary

4 Audit Result

5 Statement

1 Executive Summary

On 2023.10.19, the SlowMist security team received the MoreLogin team's security audit application for MoreLogin, developed the audit plan according to the agreement of both parties and the characteristics of the project, and finally issued the security audit report.

The SlowMist security team adopts the strategy of "black box lead, grey box assists" to conduct a complete security test on the project in the way closest to the real attack.

The test method information:

Test method	Description
Black box testing	Conduct security tests from an attacker's perspective externally.
Grey box testing	Conduct security testing on code modules through the scripting tool, observing the internal running status, mining weaknesses.
White box testing	Based on the open source code, non-open source code, to detect whether there are vulnerabilities in programs such as nodes, SDK, etc.

The vulnerability severity level information:

Level	Description
Critical	Critical severity vulnerabilities will have a significant impact on the security of the project, and it is strongly recommended to fix the critical vulnerabilities.
High	High severity vulnerabilities will affect the normal operation of the project. It is strongly recommended to fix high-risk vulnerabilities.
Medium	Medium severity vulnerability will affect the operation of the project. It is recommended to fix medium-risk vulnerabilities.
Low	Low severity vulnerabilities may affect the operation of the project in certain scenarios. It is suggested that the project team should evaluate and consider whether these vulnerabilities need to be fixed.
Weakness	There are safety risks theoretically, but it is extremely difficult to reproduce in engineering.
Suggestion	There are better practices for coding or architecture.

2 Audit Methodology

The security audit process of SlowMist security team for application includes two steps:

- The applications are scanned/tested for commonly known and more specific vulnerabilities using automated analysis tools.
- Manual audit of the applications for security issues. The applications are manually analyzed to look for any potential issues.

The following is a list of security audit items considered during an audit:

NO.	Audit Items	Result
1	App runtime environment detection	Passed
2	Code decompilation detection	Fixed
3	App permissions detection	Passed
4	File storage security audit	Passed
5	Communication encryption security audit	Acknowledged
6	Interface security audit	Fixed
7	Business security audit	Fixed
8	App cache security audit	Passed
9	SQLite storage security audit	Passed
10	WHOIS information collection	Passed
11	Real IP discovery	Passed
12	Subdomain detection	Passed
13	Mail service detection	Passed
14	Certificate information collection	Passed
15	Web services component fingerprint collection	Passed

NO.	Audit Items	Result
16	Port service component fingerprint collection	Passed
17	Segment C service acquisition	Passed
18	Personnel structure collection	Passed
19	GitHub source code leak detection	Passed
20	Google Hack detection	Passed
21	Privacy data leak detection	Passed
22	CDN service detection	Passed
23	Network infrastructure configuration test	Fixed
24	Application platform configuration management test	Fixed
25	File extension resolution test	Passed
26	Backup, unlinked file test	Passed
27	Enumerate management interface test	Passed
28	HTTP method test	Passed
29	HTTP strict transmission test	Passed
30	Web front-end cross-domain policy test	Passed
31	Web security response header test	Fixed
32	Weak password and default password detection	Passed
33	Role definition test	Passed
34	User registration process test	Fixed
35	Account rights change test	Passed
36	Account enumeration test	Passed
37	Weak username strategy testing	Passed
38	Password information encrypted transmission test	Fixed

NO.	Audit Items	Result
39	Default password test	Passed
40	Account lockout mechanism test	Passed
41	Certification bypass test	Passed
42	Password memory function test	Passed
43	Browser cache test	Passed
44	Password strategy test	Passed
45	Password reset test	Fixed
46	OAuth authentication model test	Passed
47	Privilege escalation test	Passed
48	Authorization bypass test	Passed
49	Two-factor authentication bypass test	Acknowledged
50	Hash robustness test	Passed
51	Session management bypass test	Passed
52	Cookies property test	Passed
53	Session fixation test	Passed
54	Session token leak test	Passed
55	Cross Site Request Forgery (CSRF) test	Passed
56	Logout function test	Passed
57	Session timeout test	Passed
58	Session token overload test	Passed
59	Cross Site Scripting (XSS) test	Fixed
60	Template injection test	Passed

NO.	Audit Items	Result
61	Third-party component vulnerability test	Passed
62	HTTP parameter pollution test	Passed
63	SQL injection test	Passed
64	XXE entity injection test	Passed
65	Deserialization vulnerability test	Passed
66	SSRF vulnerability test	Passed
67	Code injection test	Passed
68	Local file contains test	Passed
69	Remote file contains test	Passed
70	Command execution injection test	Passed
71	Buffer overflow test	Passed
72	Formatted string test	Passed
73	Interface security test	Passed
74	Request forgery test	Passed
75	Integrity test	Confirmed
76	Overtime detection	Passed
77	Interface frequency limit test	Passed
78	Workflow bypass test	Passed
79	Application misuse protection test	Passed
80	Unexpected file type upload test	Fixed
81	Malicious file upload test	Passed
82	Weak SSL/TLS encryption, insecure transport layer protection test	Fixed
83	SSL pinning security deployment test	Passed

NO.	Audit Items	Result
84	Non-encrypted channel transmission of sensitive data test	Passed

3 Project Overview

3.1 Project Introduction

Audit Version

Version: 1.1.99

macOS

Download link:

https://get.morelogin.com/prod/MoreLogin%20AirDrop_darwin_arm64/MoreLogin%20AirDrop_arm64_1.1.99.dmg

shasum256: bcc5b0ea6b246fbf69d21fbe94f08f88b59bd52ba918a4f94d06a42cdfd2e85c

Windows

Download link: https://get.morelogin.com/client/prod/win/x64/1.1.99/MoreLogin%20AirDrop_x64_1.1.99.exe

shasum256: 63cddce5cd509b54dd78d1fcc488894999217119a76731940170c02ef174d9cf

Fixed Version

macOS

Version: 1.2.1

Download link:

https://get.morelogin.com/prod/MoreLogin_AirDrop_darwin_arm64/MoreLogin_AirDrop_arm64_1.2.1.dmg

shasum256: de18908f09e55559cfc02fd496ed1cc4ea827113bd6f0afb09c97a1c9a9f0da9

Windows

Version: 1.2.2

Download link: https://get.morelogin.com/client/prod/win/x64/1.2.2/MoreLogin_AirDrop_x64_1.2.2.exe

shasum256: 0ad3715e5985cf7760cedd34fca2108b9215480c56ec6bb2719620ae144e8057

3.2 Vulnerability Information

The following is the status of the vulnerabilities found in this audit:

NO	Title	Category	Level	Status
N1	User registration process issue	User registration process test	Low	Fixed
N2	Password reset issue	Password reset test	Low	Fixed
N3	Password information encrypted transmission issue	Password information encrypted transmission test	Suggestion	Fixed
N4	Communication encryption security issue	Communication encryption security audit	Suggestion	Acknowledged
N5	Missing two-factor authentication	Two-factor authentication bypass test	Suggestion	Acknowledged
N6	Interface leaks developer information	Interface security audit	Suggestion	Fixed
N7	Missing DNSSEC security configuration	Network infrastructure configuration test	Suggestion	Fixed
N8	Allowing communication with older TLS versions	Weak SSL/TLS encryption, insecure transport layer protection test	Suggestion	Fixed
N9	Missing web security response header	Web security response header test	Suggestion	Fixed
N10	Unlimited environment creation	Business security audit	High	Fixed
N11	Unauthorized Deletion of Others' Environments	Business security audit	High	Fixed
N12	Unauthorized Modification of	Business security audit	High	Fixed

NO	Title	Category	Level	Status
	Others' Environments			
N13	Unauthorized Operation Authorization Activation for Others' Environments	Business security audit	Low	Fixed
N14	Incorrect Display of Member Addition Status in the Frontend	Business security audit	Suggestion	Fixed
N15	Unauthorized Deletion of Boss-level Accounts	Business security audit	Suggestion	Fixed
N16	Unexpected file type upload issue	Unexpected file type upload test	Medium	Fixed
N17	Lack of Minimum Recharge Amount Restriction on the Server	Business security audit	Low	Fixed
N18	Source Map Leads to Source Code Leakage	Code decompilation detection	Suggestion	Fixed
N19	Leakage of Sensitive Information in Error Messages	Interface security audit	Suggestion	Fixed
N20	Lack of File Integrity Verification in MoreLogin	Integrity test	Suggestion	Confirmed
N21	Cross Site Scripting (XSS) issue	Cross Site Scripting (XSS) test	Low	Fixed
N22	Information Leakage in Spring Boot	Application platform configuration management test	Suggestion	Fixed

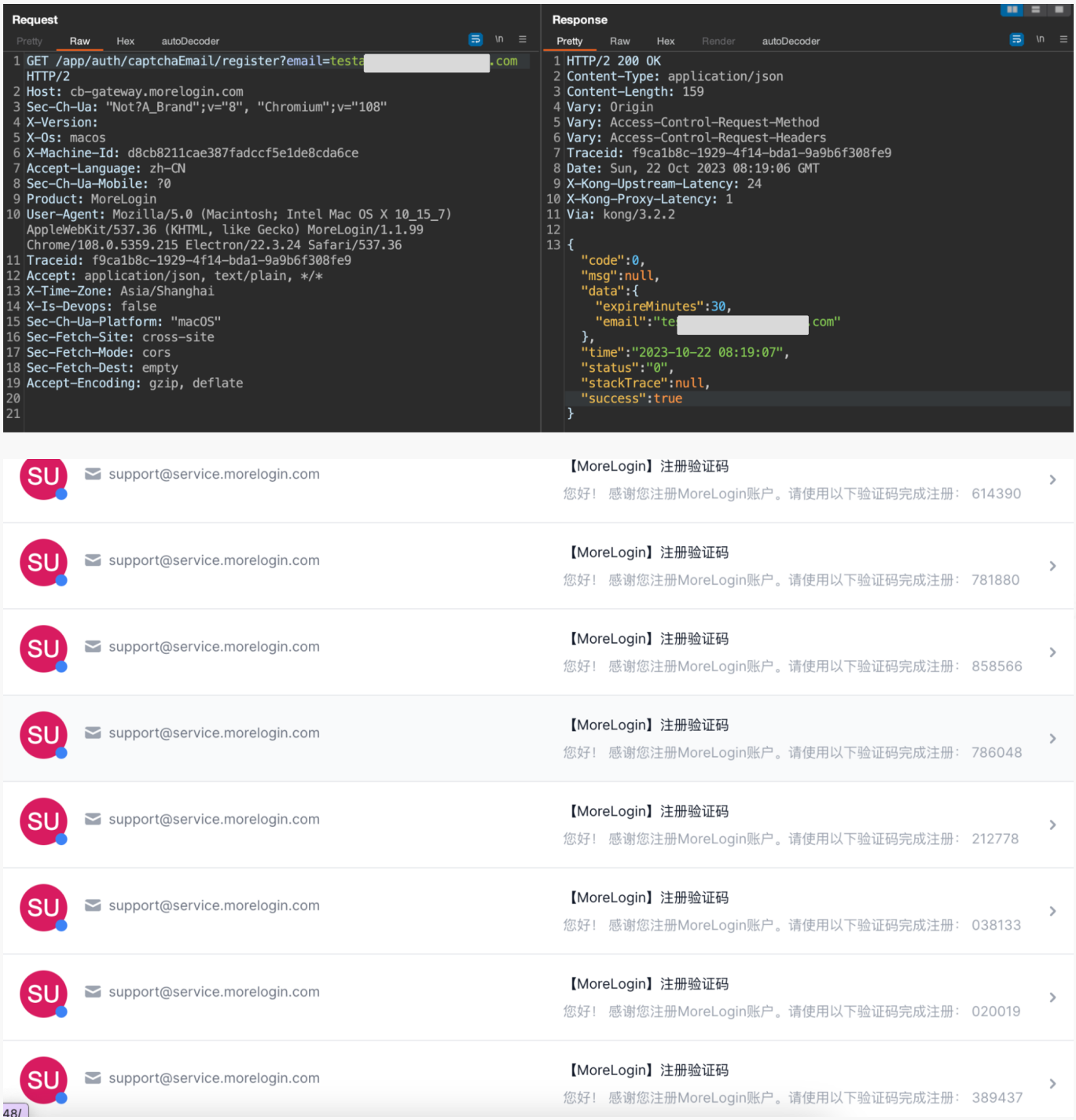
3.3 Vulnerability Summary

[N1] [Low] User registration process issue

Category: User registration process test

Content

Registration can be done through two options: "Register via Google" and "Register using email." The email registration interface lacks human-machine verification, which can lead to email bombing issues.



The email registration interface lacks human-machine verification, which can result in email bombing issues.

Solution

It is recommended to add a human-machine verification to the registration interface.

Status

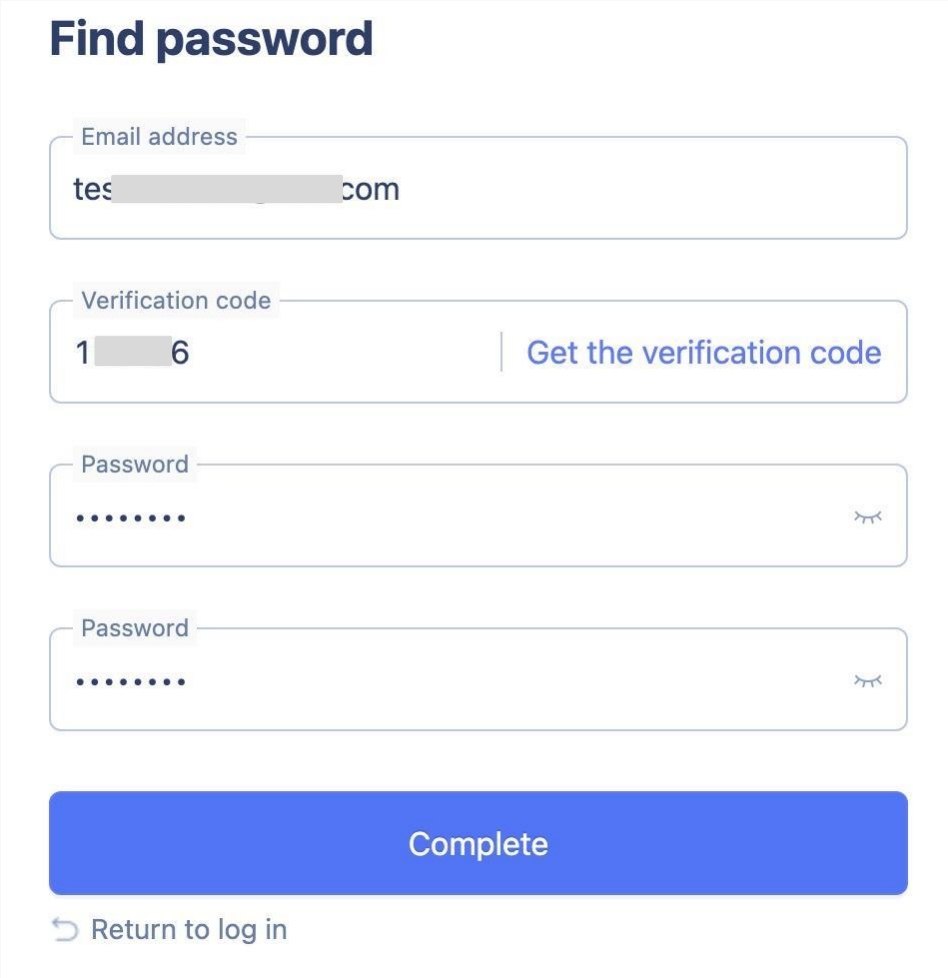
Fixed

[N2] [Low] Password reset issue

Category: Password reset test

Content

Email verification is required for password reset.



The password modification process lacks human-machine verification, which can lead to email bombing issues when obtaining the password reset verification code.

The email sending interface is: https://cb-gateway.morelogin.com/app/auth/captchaEmail/unauthPassword?

Request

```
GET /app/auth/captchaEmail/unauthPassword?email=
testa                                    m HTTP/2
Host: cb-gateway.morelogin.com
Sec-Ch-Ua: "Not?A_Brand";v="8", "Chromium";v="108"
X-Version:
X-Os: macos
X-Machine-Id: d8cb8211cae387fadccf5e1de8cda6ce
Accept-Language: zh-CN
Sec-Ch-Ua-Mobile: ?0
Product: MoreLogin
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
AppleWebKit/537.36 (KHTML, like Gecko) MoreLogin/1.1.100
Chrome/108.0.5359.215 Electron/22.3.24 Safari/537.36
Traceid: 87fd8974-b80b-40e3-b287-92a921ad414b
Accept: application/json, text/plain, */*
X-Time-Zone: Asia/Shanghai
X-Is-Devops: false
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: cross-site
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
```

Response

```
HTTP/2 200 OK
Content-Type: application/json
Content-Length: 159
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Traceid: 87fd8974-b80b-40e3-b287-92a921ad414b
Date: Mon, 23 Oct 2023 07:20:39 GMT
X-Kong-Upstream-Latency: 26
X-Kong-Proxy-Latency: 0
Via: kong/3.2.2

{
  "code":0,
  "msg":null,
  "data":{
    "expireMinutes":30,
    "email":"te                    .com"
  },
  "time":"2023-10-23 07:20:39",
  "status":"0",
  "stackTrace":null,
  "success":true
}
```

The email verification code sending interface does not have any frequency restrictions.

Request

```
GET /app/auth/captchaEmail/password HTTP/2
Host: cb-gateway.morelogin.com
Cookie: _hjSessionUser_3191371=
ey                                    zRlNj
Rm                                    nIjp0
cnVlfQ==
Sec-Ch-Ua: "Not?A_Brand";v="8", "Chromium";v="108"
X-Version: 1.1.100
X-Os: macos
X-Machine-Id: b670f65bee1a9cac3547ed97e8cbe9ec
Accept-Language: zh-CN
Sec-Ch-Ua-Mobile: ?0
Product: MoreLogin
Authorization:
8d76fc63a6bc203dbc4bf8f89a338a7c49a14a2ab811966e0138b9
c                                    ce
1                                    fc
c                                    be
bl                                   4f
dl                                   65
f                                    9e
4                                    6a
e                                    71
1d1b71619291566eebba58188a764be20408f9e9f3fa79aefe5a8a
405e03dc0bfe7721e174
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X
```

Response

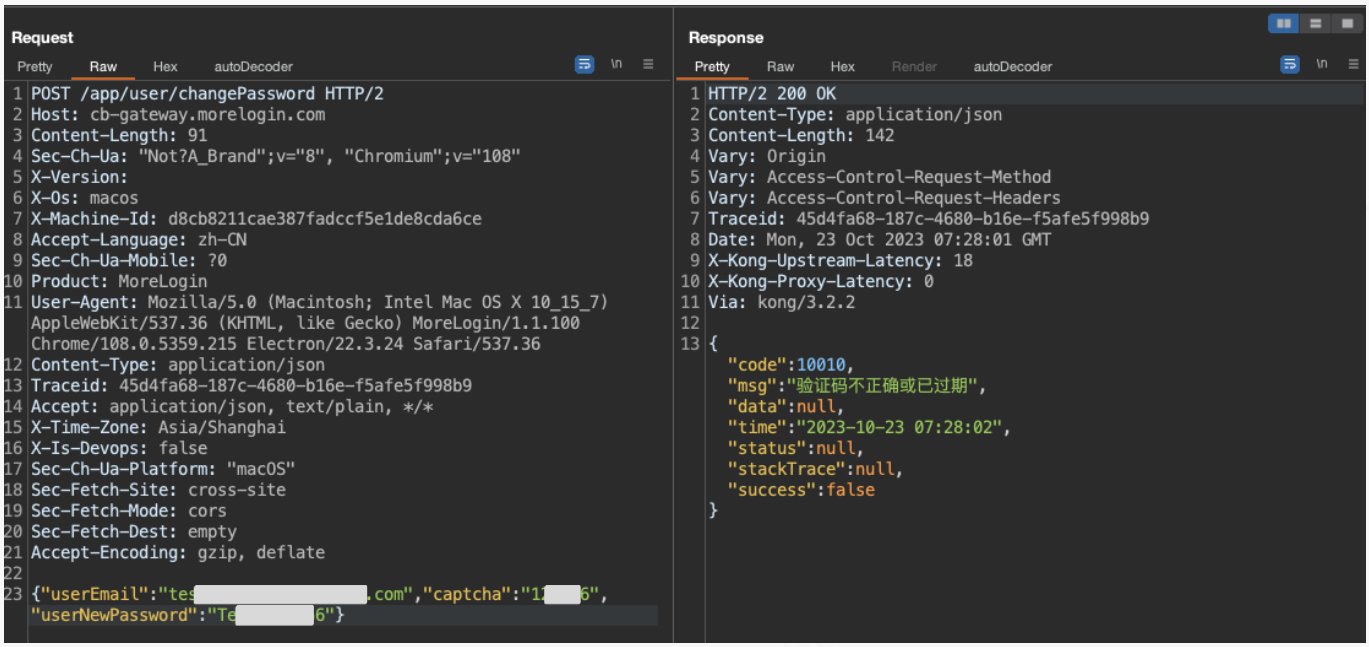
```
HTTP/2 200 OK
Content-Type: application/json
Content-Length: 216
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Traceid: be070260-feb6-433a-9aa8-b614410ef77d
Date: Mon, 23 Oct 2023 03:24:11 GMT
X-Kong-Upstream-Latency: 21
X-Kong-Proxy-Latency: 0
Via: kong/3.2.2

PpV+Z/
                                    
mFKyyzsA3taCR9+KWEhH6z2HKzNYHr6g==
```

Search... 0 matches | Search... 0 matches

Done 530 bytes | 108 millis

INSPECTOR



The password modification process lacks human-machine verification, making it vulnerable to brute-force attacks.

The email and SMS interface lacks frequency restrictions, which can potentially lead to email bombing.

Solution

It is advised to add human-machine verification during the password modification process.

It is recommended to implement frequency restrictions on the email sending interface, such as allowing only one email to be sent within a one-minute timeframe.

Status

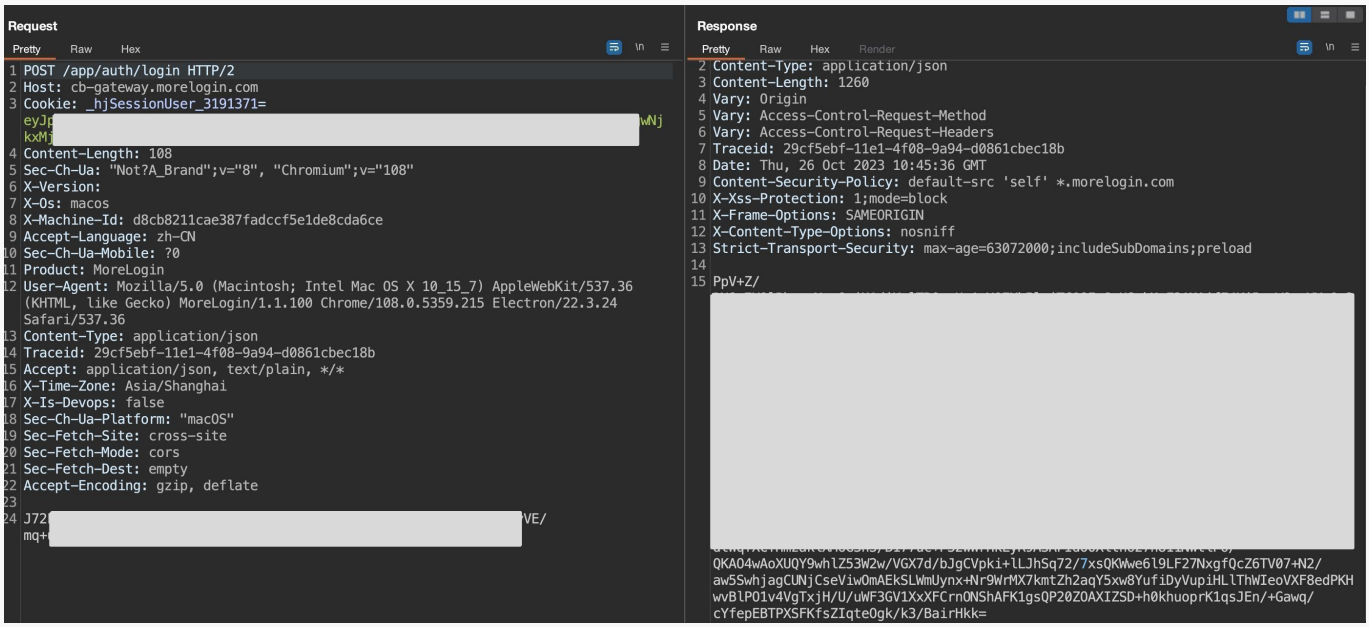
Fixed

[N3] [Suggestion] Password information encrypted transmission issue

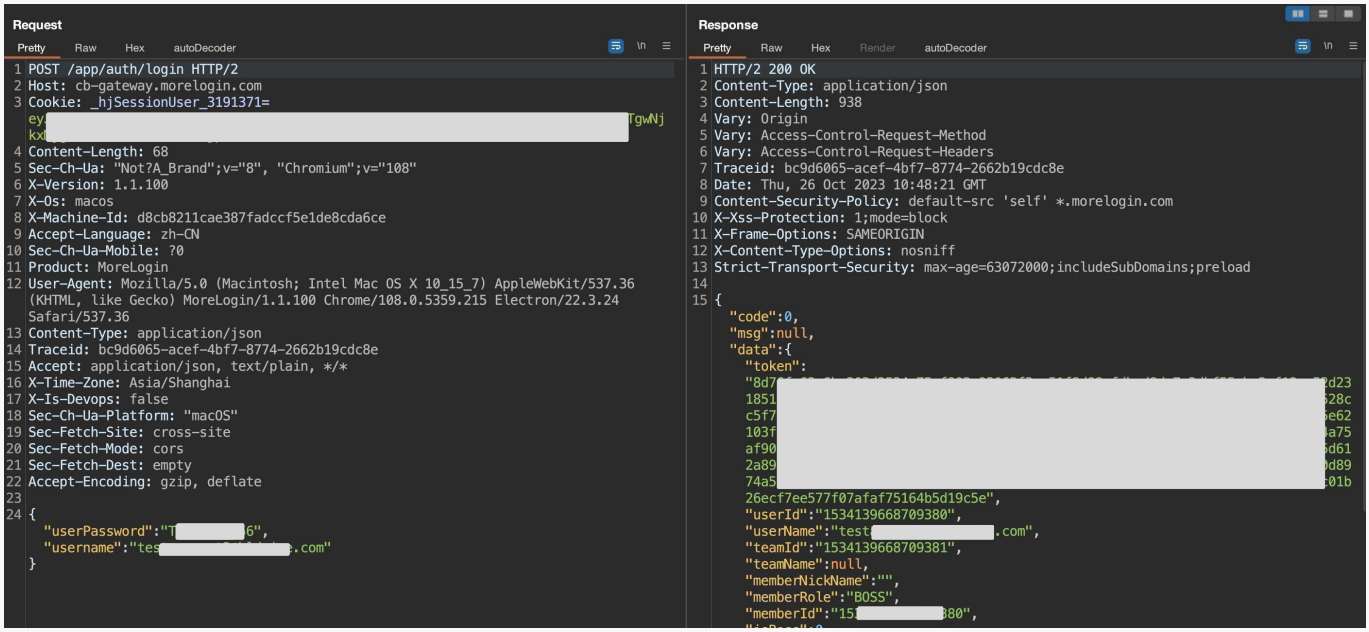
Category: Password information encrypted transmission test

Content

The account is transmitted using AES encryption.



However, the AES key and IV are fixed in the client software package, which means that for the server, there is no difference between the transmitted password and plain text.



Solution

Password setting should utilize algorithms that prevent the reverse engineering of user plaintext passwords. For example, during the registration phase, passwords should be transmitted using Sha256 and stored on the server using Sha256 with Salt.

Status

Fixed

[N4] [Suggestion] Communication encryption security issue

Category: Communication encryption security audit

Content

Most of the client-server communication data is encrypted during transmission, using the AES encryption algorithm.

(1) Encryption of Unauthenticated Request Data and Decryption by the Server

When the account is not logged in, the AES encryption algorithm is used with CBC mode and PKCS padding. The AES key and IV values used for encryption and decryption are hardcoded in the software.



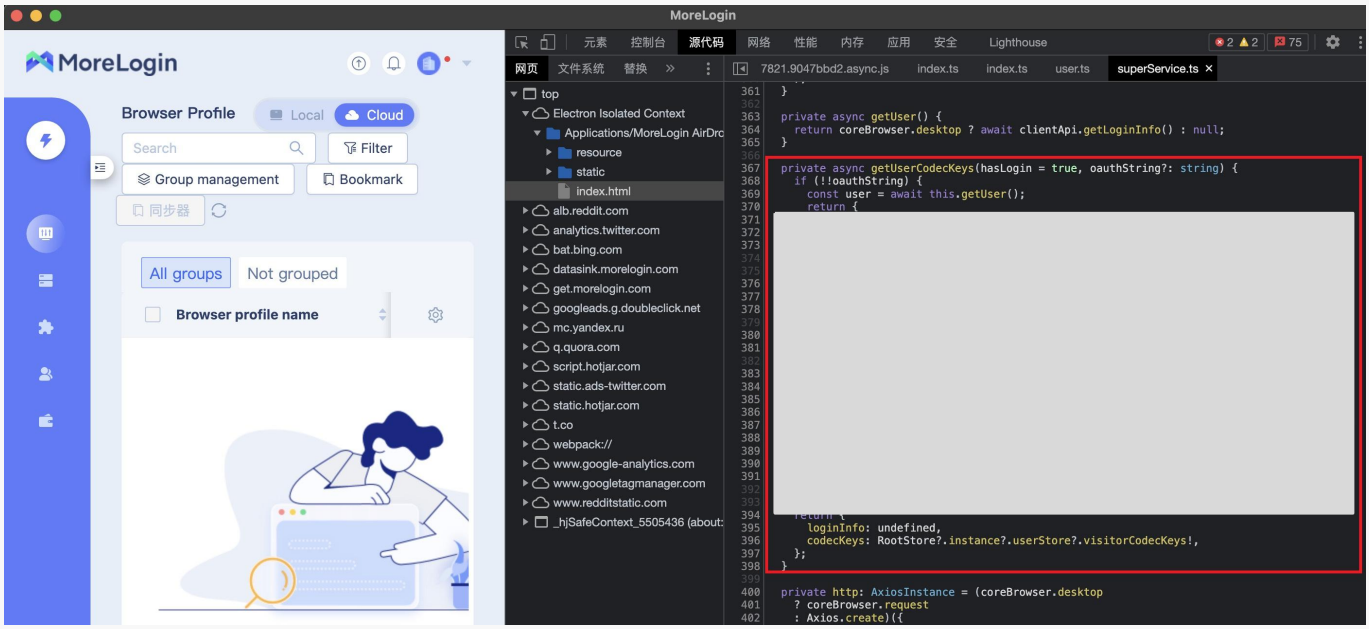
This is the AES key used for encryption before login and for decryption after login.

```
AES Key  :  [redacted]f5
AES Iv  : jM[redacted] =
```

(2) Encryption and Decryption of Request Data After Login.

For request data after login, the AES key and IV are dynamic.

After login, the client obtains the user ID and locally computed machine code to calculate the AES key and IV. The calculation method involves concatenating the user ID and machine code, and then computing the SHA256 hash. The user ID is issued by the server, while the machine code is locally generated and transmitted in the HTTP request header.



The code logic for obtaining the final Key and IV is as follows:

```
const crypto = require('crypto');
const userInfo = {
  userId: '',
};
const machineInfo = {
  MachineCode: '',
};

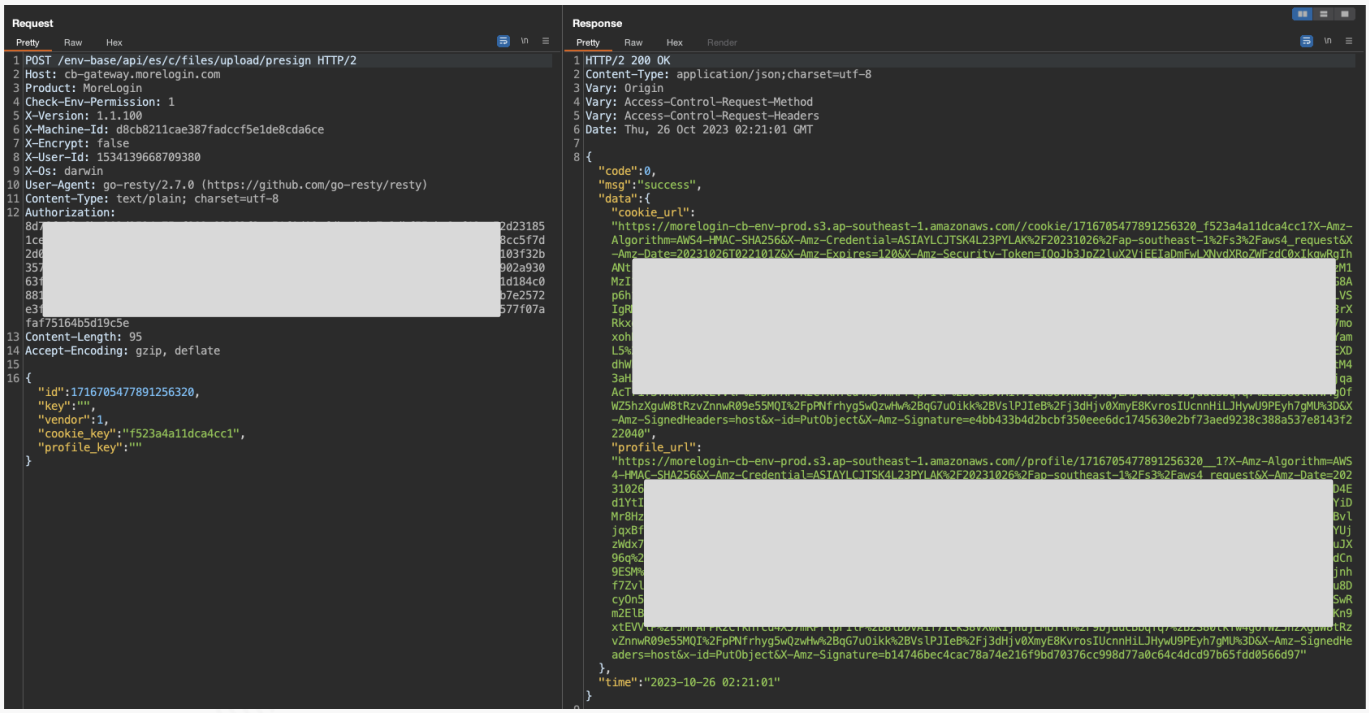
const concatenatedString = `${userInfo.userId}_${machineInfo.MachineCode}`;
const hash = crypto.createHash('sha256').update(concatenatedString).digest('hex');
const Key = hash.substring(0,16);
const iv = hash.substring(64-16);
```

(3) Cloud Data Synchronization

In the case of enabling cloud synchronization mode and configuring data synchronization, cloud data synchronization can be categorized into two types: cookie-related information and configuration-related information.

Both types of information are uploaded to an S3 storage bucket.

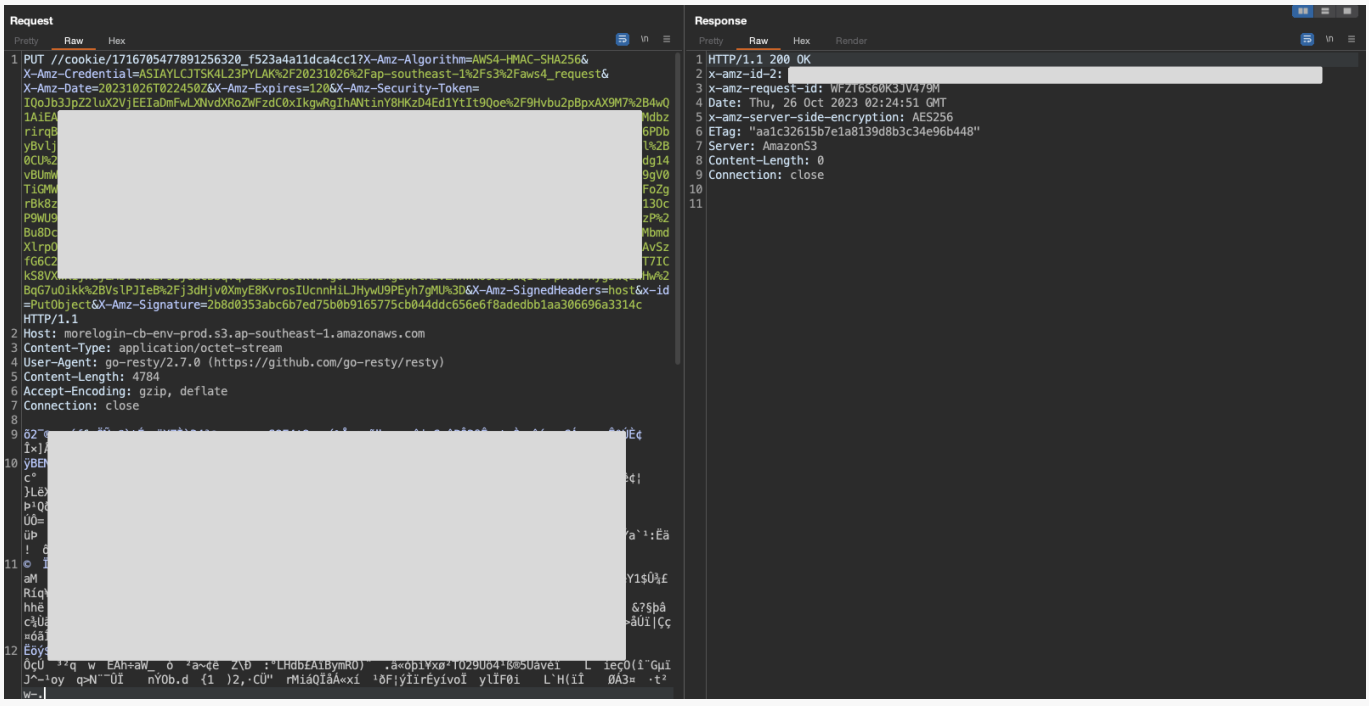
First, obtain a pre-signed URL by using the interface https://cb-gateway.morelogin.com/env-base/api/es/c/files/upload/presign.



Upload the encrypted information to the S3 storage bucket in the cloud using the PUT method.

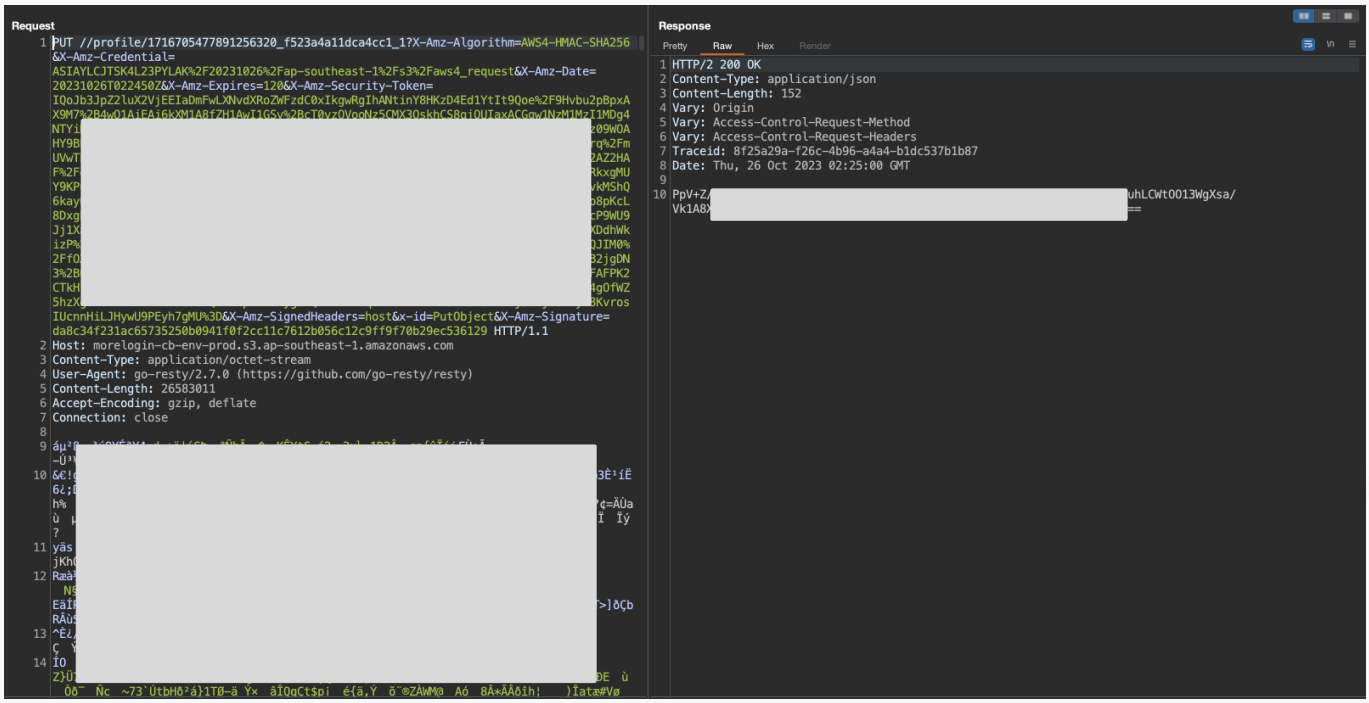
Cookie-related data upload link:

https://morelogin-cb-env-prod.s3.ap-southeast-1.amazonaws.com//cookie/

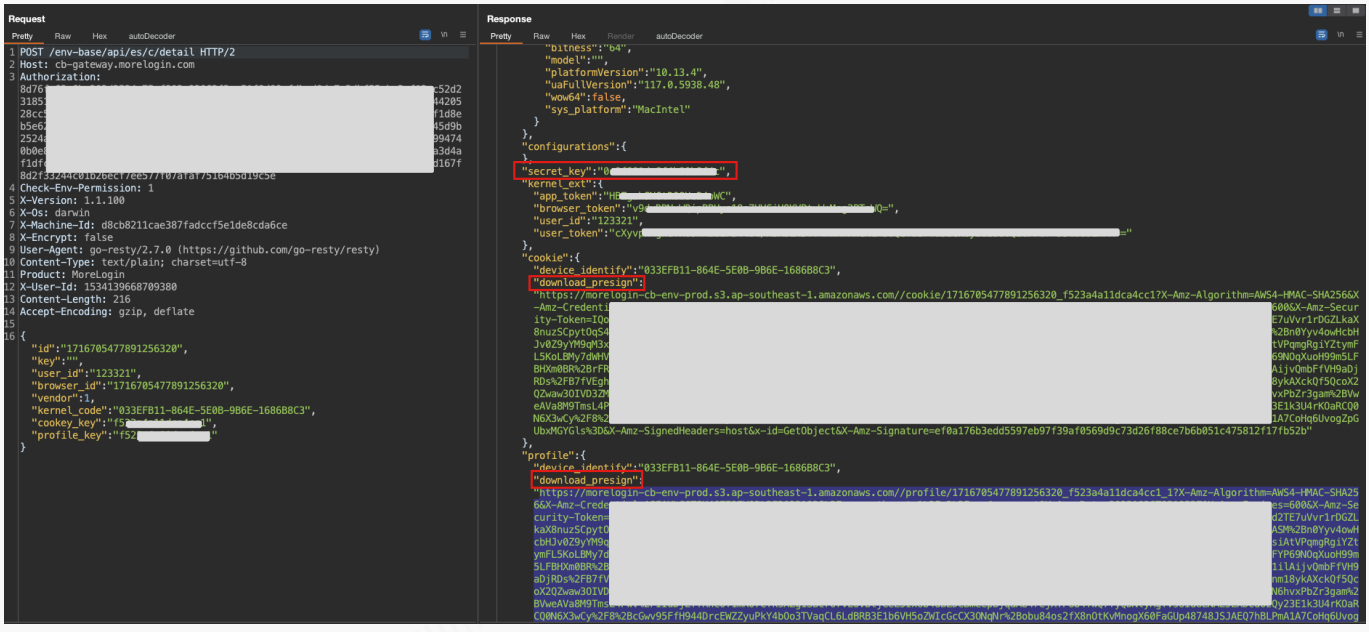


Profile-related data upload link:

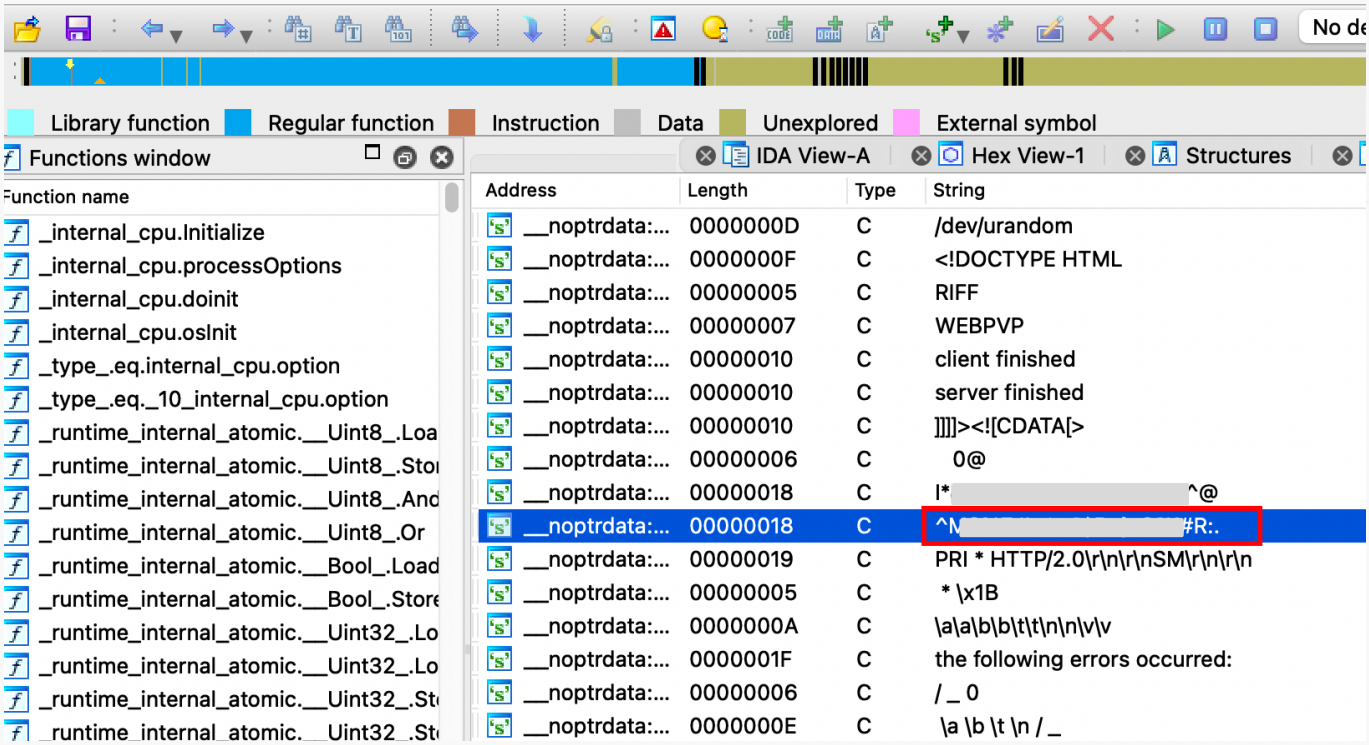
https://morelogin-cb-env-prod.s3.ap-southeast-1.amazonaws.com//profile/



The data is encrypted using AES encryption. The decryption key for the cookie is obtained from the server, while the IV is located in the program package. The client synchronization method uses the following interface:https://cb-gateway.morelogin.com/env-base/api/es/c/detail.



The AES key used for decryption is the `secret_key` returned by the server, while the IV is located on the client side. By decompiling the "env-kit" program, the IV value is obtained as `^M` .



The decryption key for the encrypted communication data does not include any elements known only to the user. The server possesses all the necessary elements to decrypt the data uploaded by the user.

Solution

It is recommended to ensure that sensitive data can only be decrypted by the user themselves. One approach is to add a password that is used in the encryption and decryption process. The password should be protected using PBKDF2.

Status

Acknowledged

[N5] [Suggestion] Missing two-factor authentication

Category: Two-factor authentication bypass test

Content

Lack of Two-Factor Authentication for Login, Password Reset, and Order Placement.

Solution

It is recommended to add 2FA authentication to the core functionality.

Status

Acknowledged

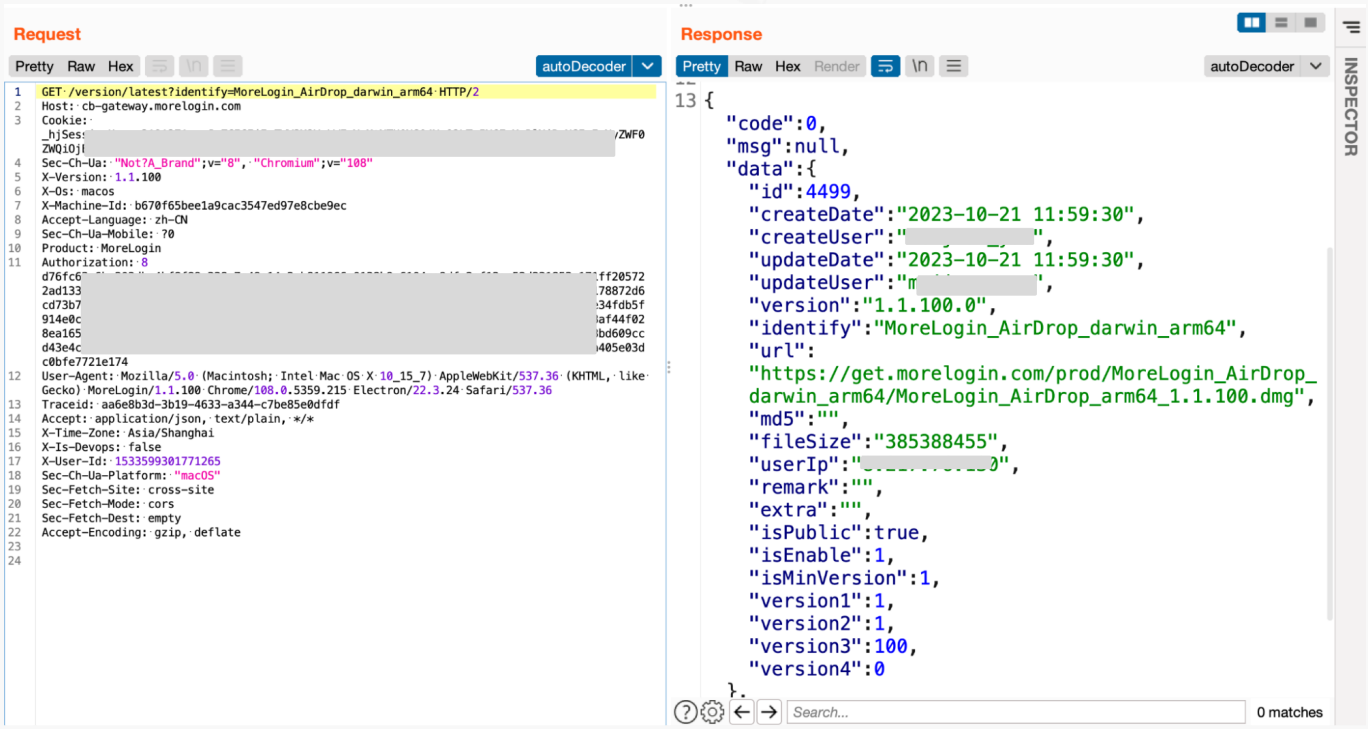
[N6] [Suggestion] Interface leaks developer information

Category: Interface security audit

Content

The interface for querying version information leaks developer details and needs some level of shielding.

Interface Link: cb-gateway.morelogin.com/version/latest?identify=MoreLogin_AirDrop_darwin_arm64"



Solution

It is recommended that the version information query interface does not return developer information.

Status

Fixed

[N7] [Suggestion] Missing DNSSEC security configuration

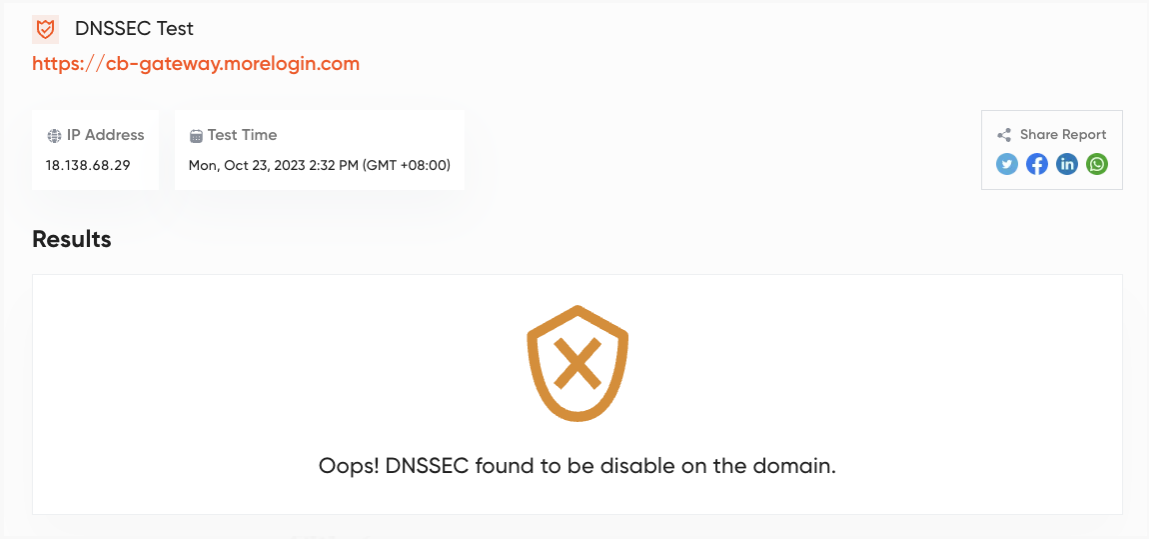
Category: Network infrastructure configuration test

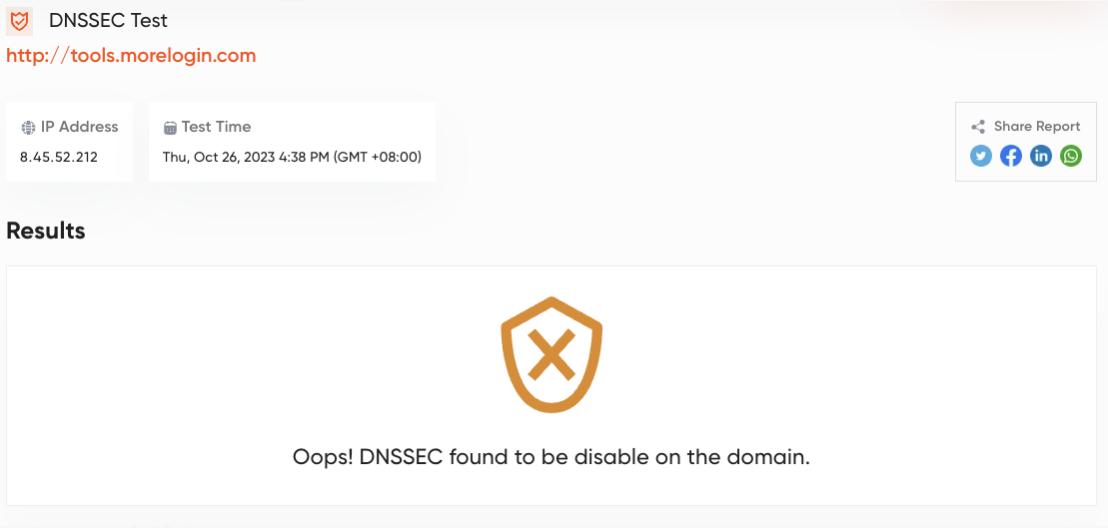
Content

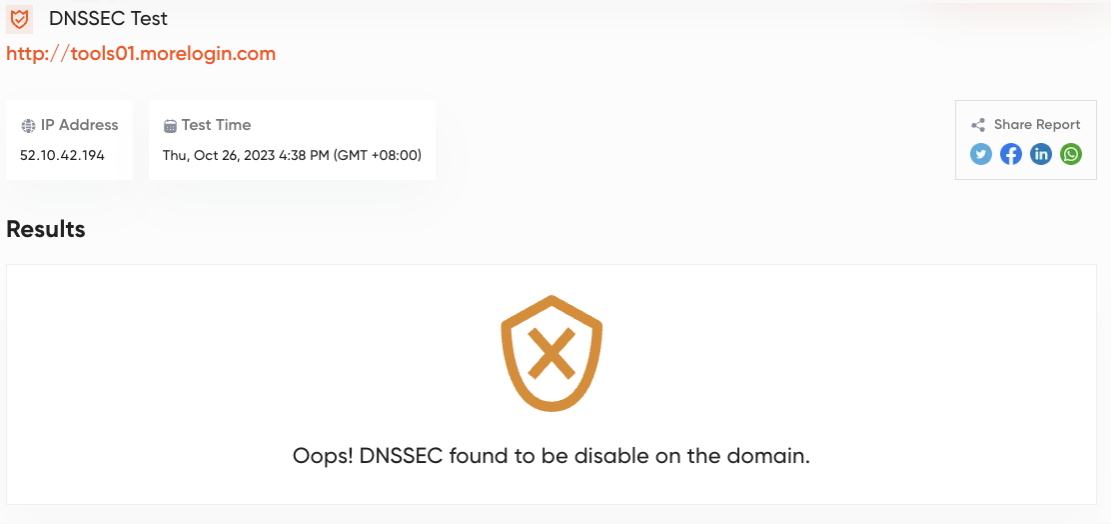
MoreLogin communicates with the following domains and upon inspection, these domains have not been configured with DNSSEC security policies.

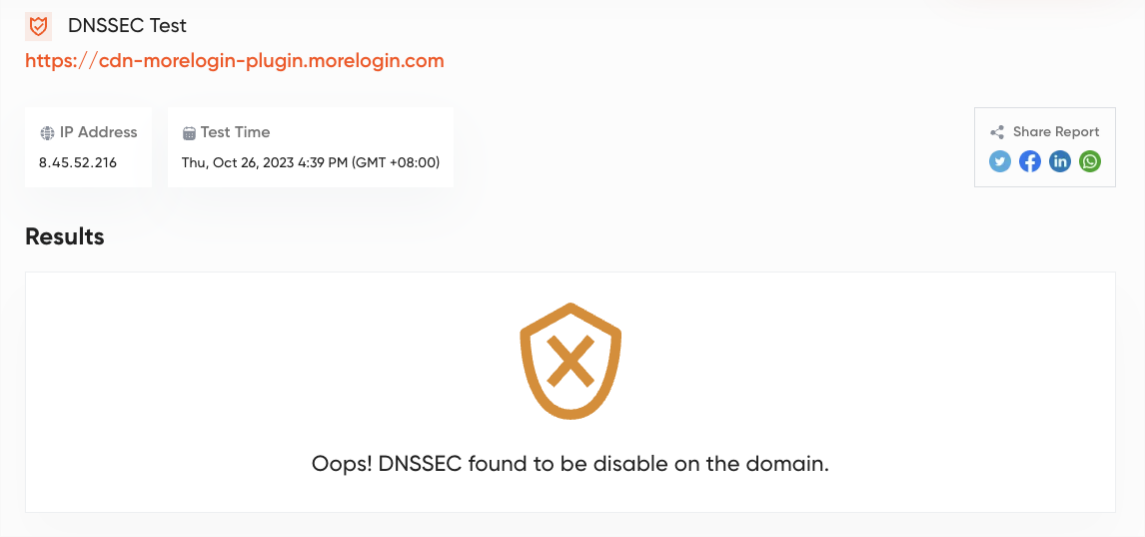
- http://tools.morelogin.com
- http://tools01.morelogin.com

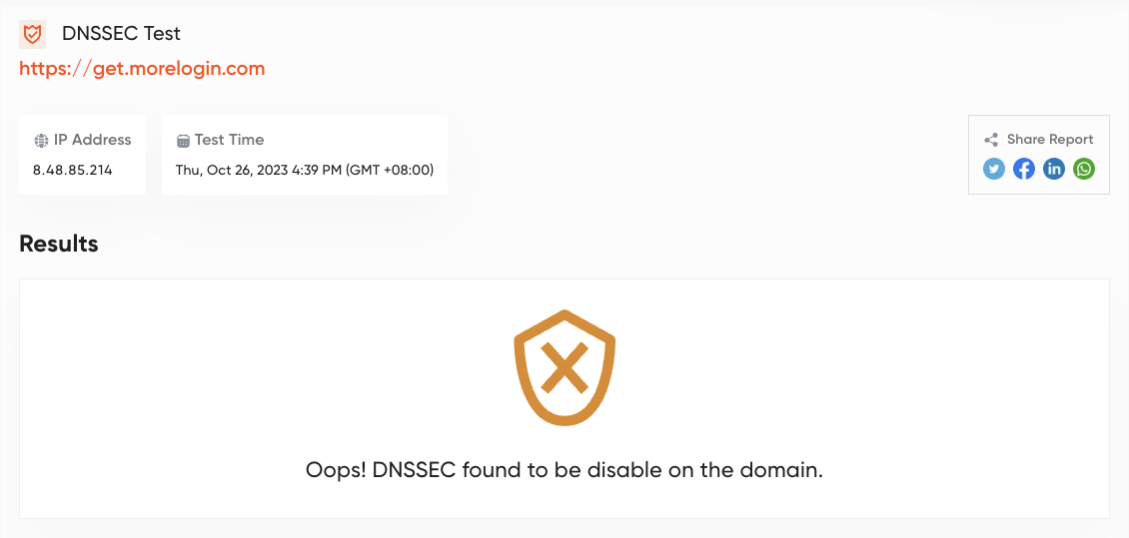
- https://cdn-morelogin-plugin.morelogin.com
- https://get.morelogin.com
- cb-gateway.morelogin.com











Solution

It is recommended to enable DNS security with the domain name resolution service provider.

Status

Fixed

[N8] [Suggestion] Allowing communication with older TLS versions

Category: Weak SSL/TLS encryption, insecure transport layer protection test

Content

MoreLogin uses a total of 5 domain names to communicate with the server, and upon inspection, it was found that 3 of these domains are configured to allow communication using older TLS versions.

- tools01.morelogin.com
- cdn-morelogin-plugin.morelogin.com

- get.morelogin.com

```
Testing SSL server tools01.morelogin.com on port 443 using SNI name tools01.morel
ogin.com

  SSL/TLS Protocols:
SSLv2     disabled
SSLv3     disabled
TLSv1.0   enabled
TLSv1.1   enabled
TLSv1.2   enabled
TLSv1.3   disabled
```

```
Testing SSL server cdn-morelogin-plugin.morelogin.com on port 443 using SNI name
cdn-morelogin-plugin.morelogin.com

  SSL/TLS Protocols:
SSLv2     disabled
SSLv3     disabled
TLSv1.0   disabled
TLSv1.1   disabled
TLSv1.2   enabled
TLSv1.3   enabled
```

```
Testing SSL server get.morelogin.com on port 443 using SNI name get.morelogin.com

  SSL/TLS Protocols:
SSLv2     disabled
SSLv3     disabled
TLSv1.0   disabled
TLSv1.1   disabled
TLSv1.2   enabled
TLSv1.3   enabled
```

Solution

It is recommended to disabling TLS versions below TLSv1.2.

Status

Fixed;

[N9] [Suggestion] Missing web security response header

Category: Web security response header test

Content

A security header check was conducted on the domain cb-gateway.morelogin.com, revealing the absence of the following configured security headers.

- X-Xss-Protection
- X-Frame-Options
- X-Content-Type-Options
- Strict-Transport-Security
- Content-Security-Policy

Solution

It is recommended to configure the appropriate security headers accordingly.

Status

Fixed

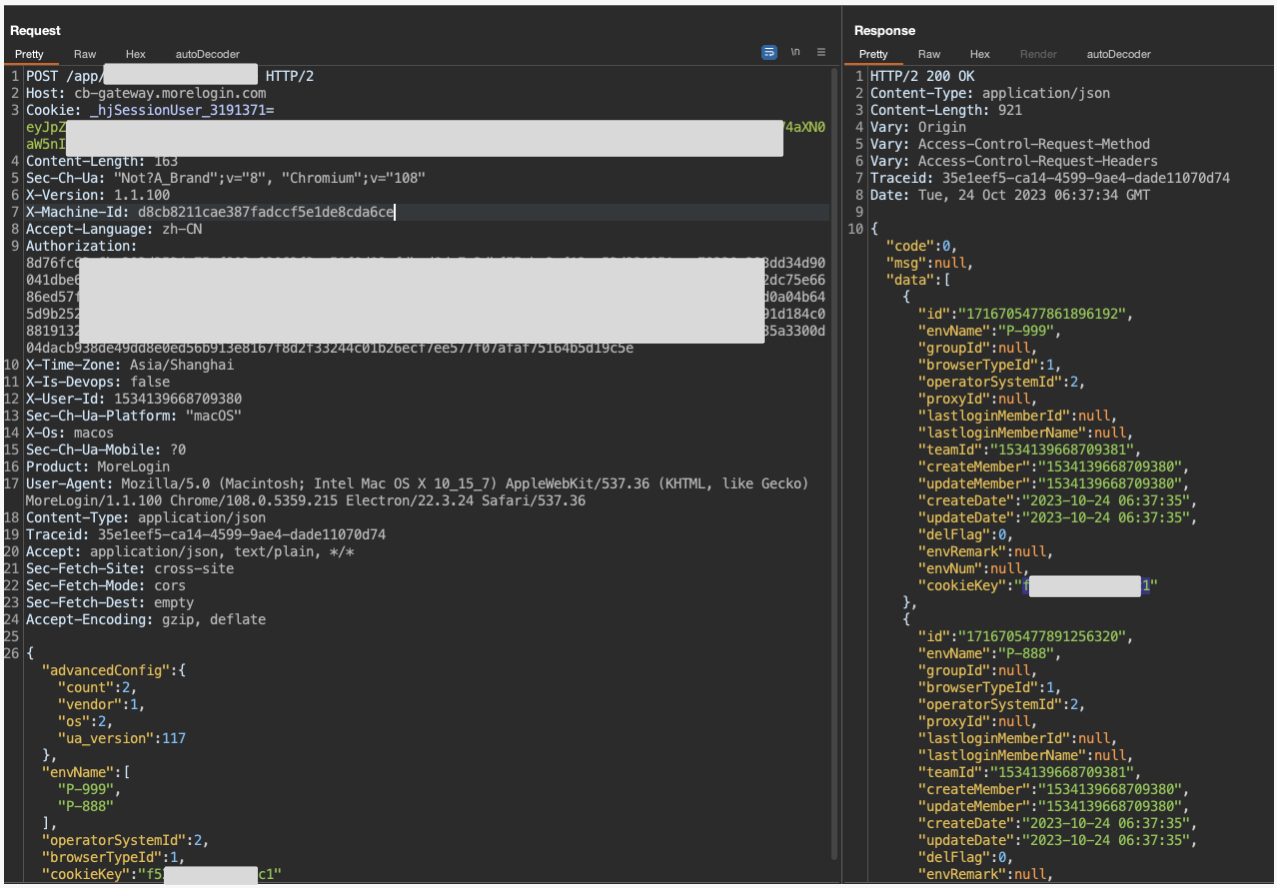
[N10] [High] Unlimited environment creation

Category: Business security audit

Content

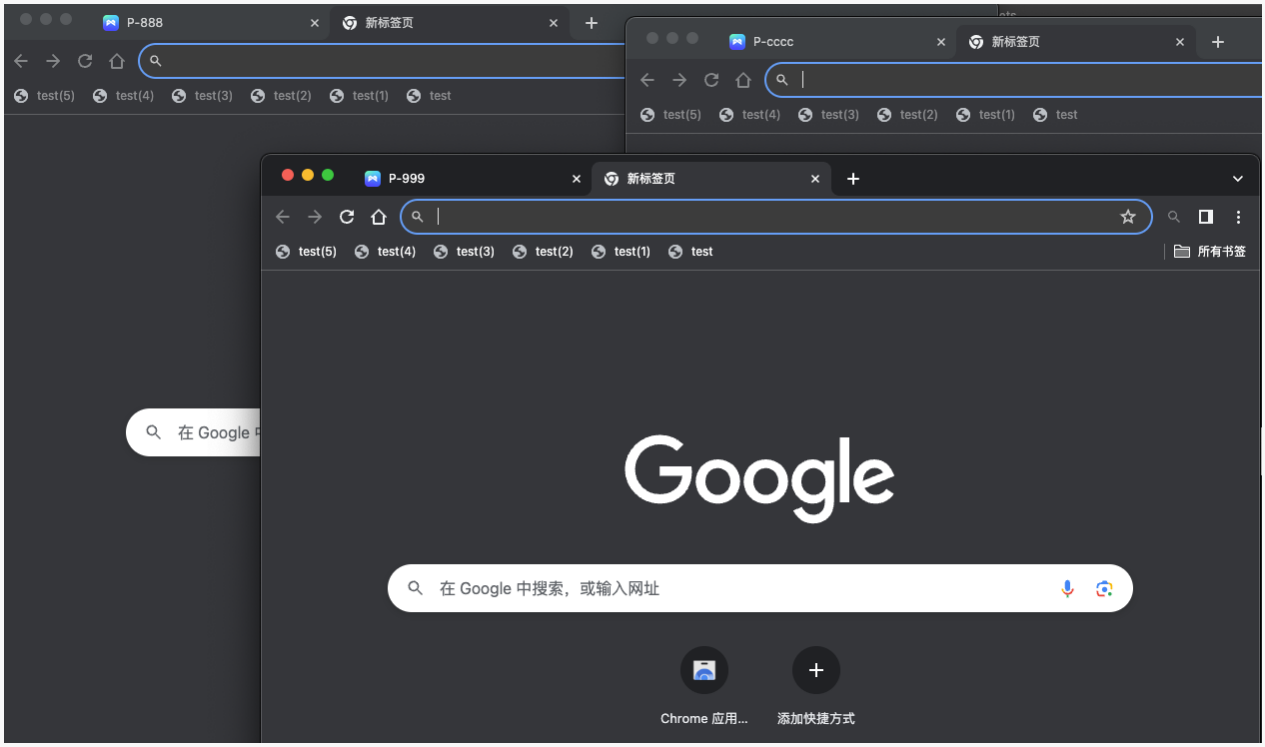
The interface for creating environments directly through the "quickCreate" API allows the creation of environments without counting towards the overall environment limit, thereby bypassing the maximum limit on the number of environments that can be created.

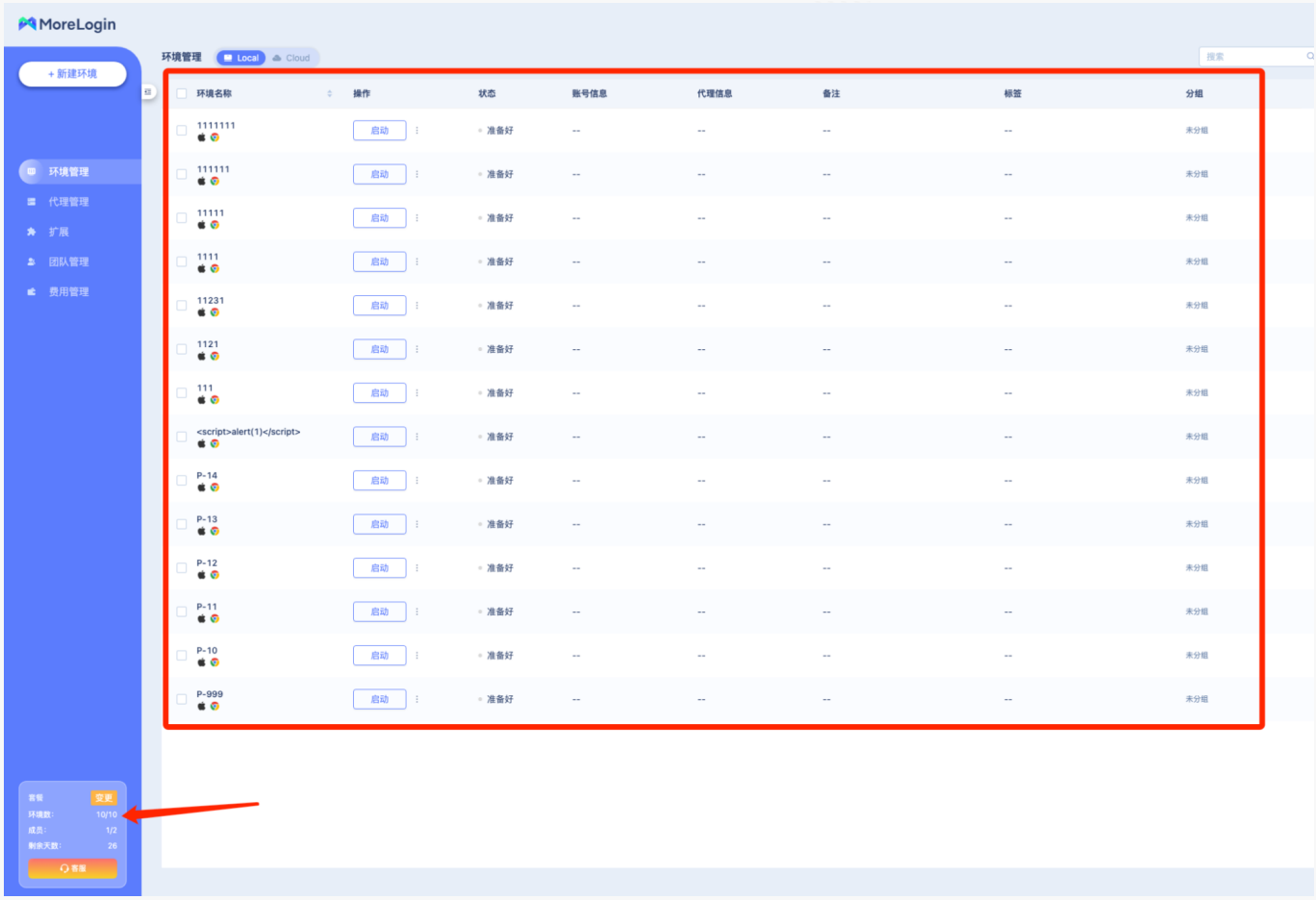
The API request for creating a new environment is: "https://cb-gateway.morelogin.com .



The interface for creating environments does not have any limitations on the quantity, allowing the creation of an unlimited number of environments.


MoreLogin
+ 新建环境
环境管理
代理管理
扩展
团队管理
费用管理
套餐 升级
环境数: 6/2
成员: 2/2
启动数: 4/20
客服
环境管理
Local
Cloud
搜索
全部分组
aa
a
未分组
环境名称
操作
状态
账号信息
P-888
停止
已启动
P-999
停止
已启动
P-cccc
停止
已启动
P-sss
启动
准备好
P-8
启动
准备好
P-7
启动
准备好
升级套餐


P-888
新标签页
P-cccc
新标签页
P-999
新标签页
test(5)
test(4)
test(3)
test(2)
test(1)
test
所有书签
在 Google 中搜索，或输入网址
Google
Chrome 应用...
添加快捷方式



The "cookieKey" parameter in the request payload for creating environments does not expire after use, allowing the request payload to be replayed indefinitely.

The interface for creating environments does not impose any limitations on the number of requests, thus enabling the creation of an unlimited number of environments.

Solution

It is recommended that the "cookieKey" parameter in the request payload for creating environments be invalidated after a single use.

Creating environments should not be limited to frontend restrictions and reminders.

server-side validation should also be implemented to check the maximum allowable number of environments that can be created.

Status

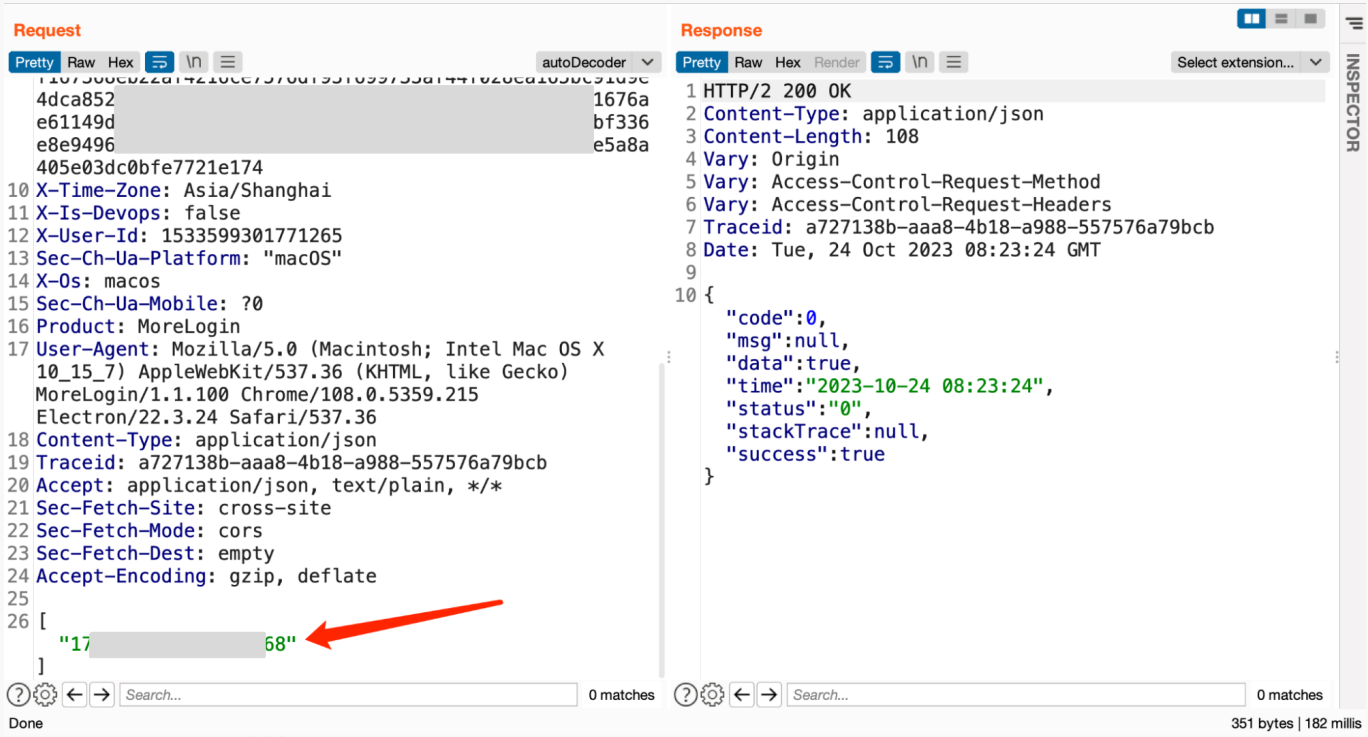
Fixed

[N11] [High] Unauthorized Deletion of Others' Environments

Category: Business security audit

Content

Horizontal privilege escalation allows the deletion of environments using another user's environment ID.



Solution

It is recommended to apply strict permission checks and limitations to the delete environment API.

Status

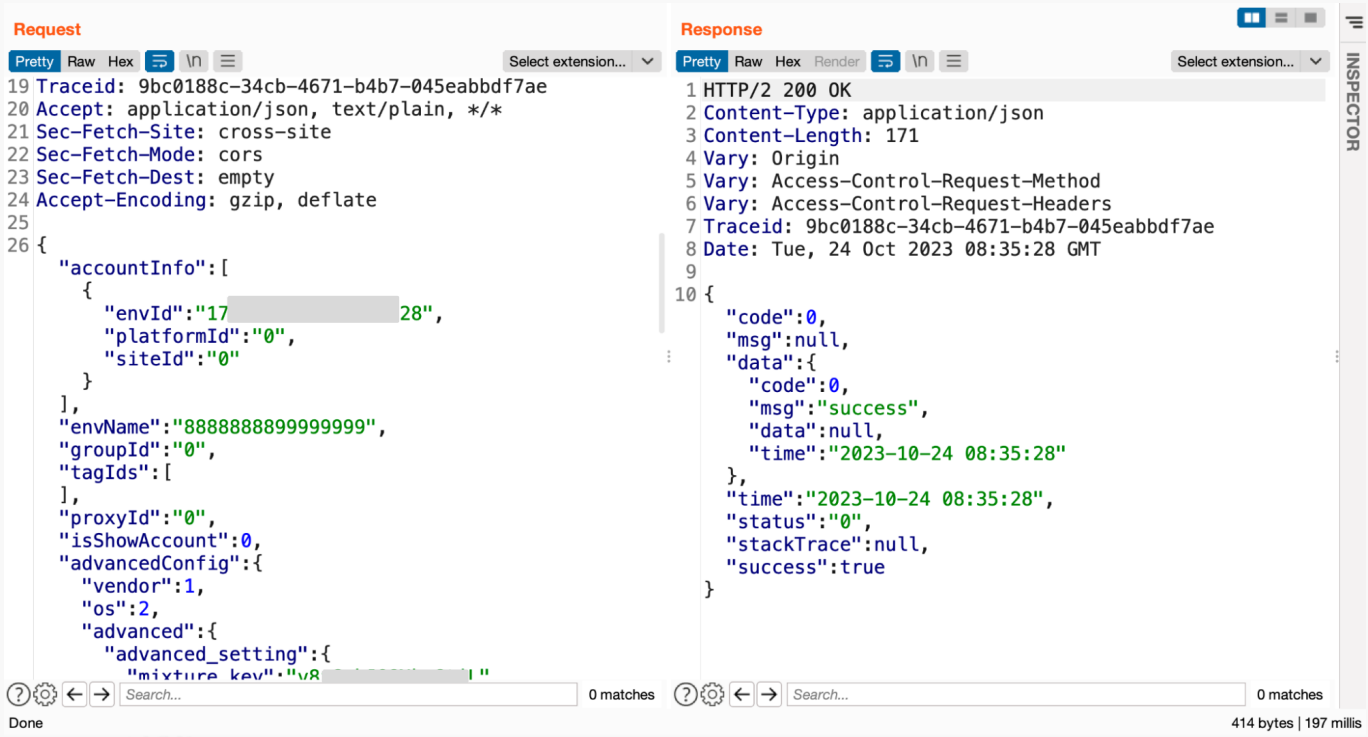
Fixed

[N12] [High] Unauthorized Modification of Others' Environments

Category: Business security audit

Content

Horizontal privilege escalation allows the modification of environments using another user's environment ID.



Solution

It is recommended to implement strict permission checks and limitations on the modify environment API to prevent unauthorized access.

Status

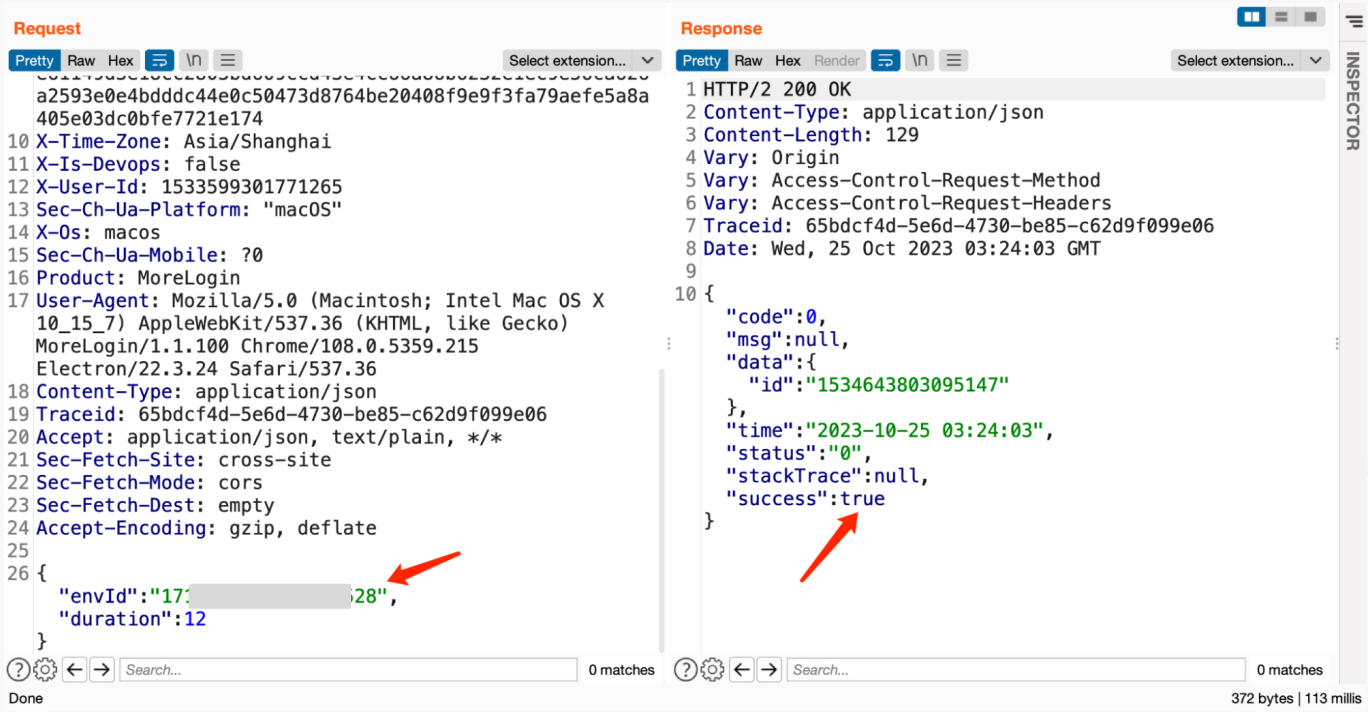
Fixed

[N13] [Low] Unauthorized Operation Authorization Activation for Others' Environments

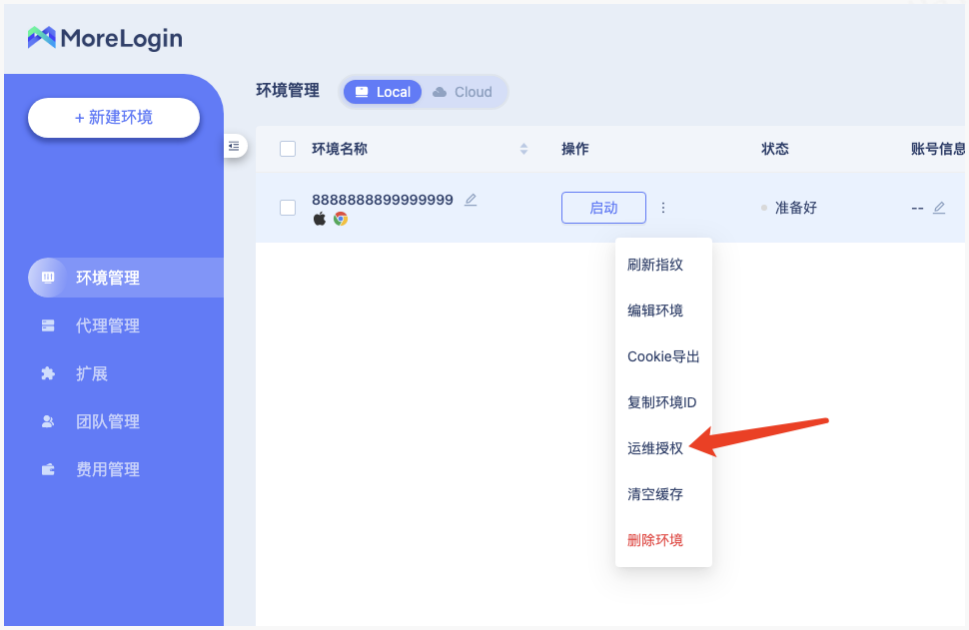
Category: Business security audit

Content

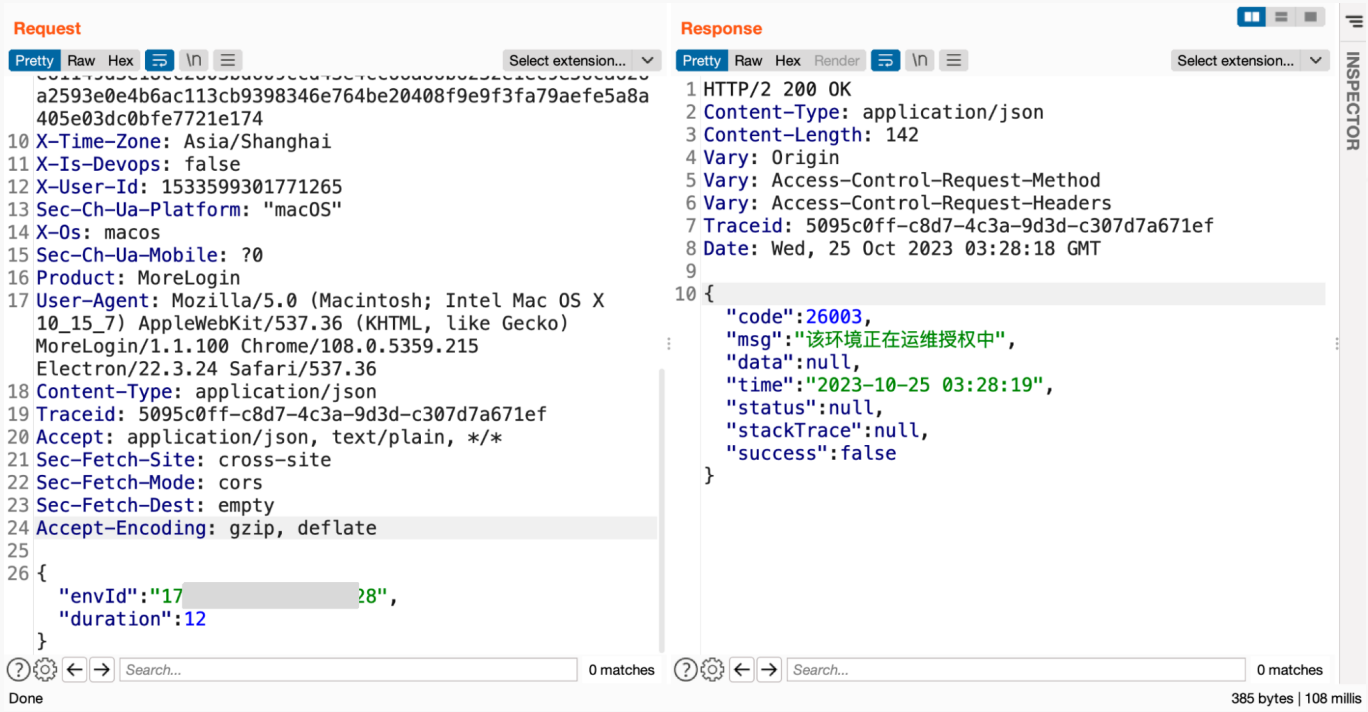
User's operational authorization can be enabled using another user's environment ID.



Even after activation, the frontend page of the target environment still shows it as disabled.



Repeatedly sending the request to activate operational authorization using the target environment ID returns the message "This environment is currently under operational authorization," indicating that the operational authorization service has already been enabled.



Solution

It is recommended to implement strict permission checks and limitations on the Operation Authorization API to prevent unauthorized access.

Status

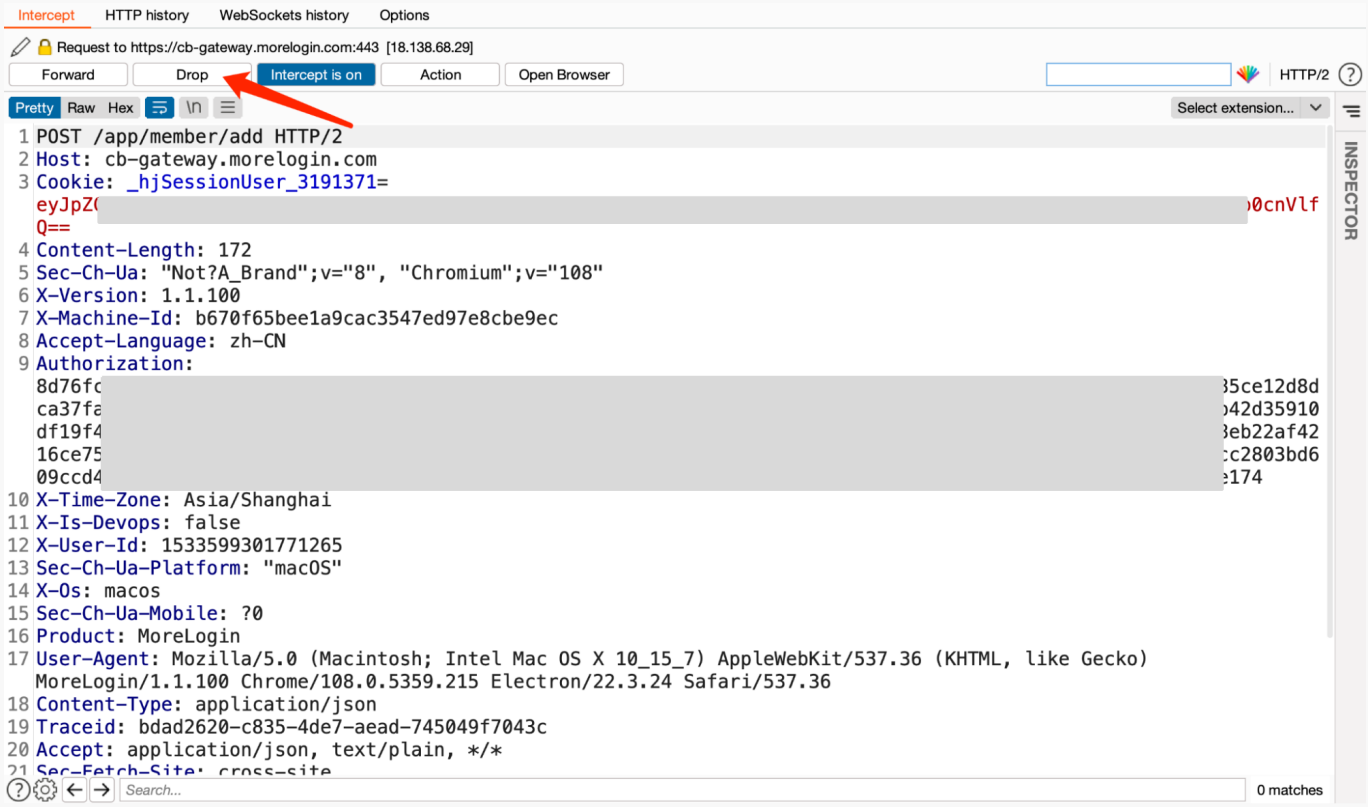
Fixed

[N14] [Suggestion] Incorrect Display of Member Addition Status in the Frontend

Category: Business security audit

Content

The frontend incorrectly displays a successful submission when adding members, even though the request packet is dropped (simulating a scenario where packet transmission fails due to network issues or other uncontrollable factors).





The frontend returns a successful addition without verifying whether the request packet was successfully sent when adding members.

Solution

It is recommended that the frontend display the correct prompt message based on the content of the response packet.

Status

Fixed

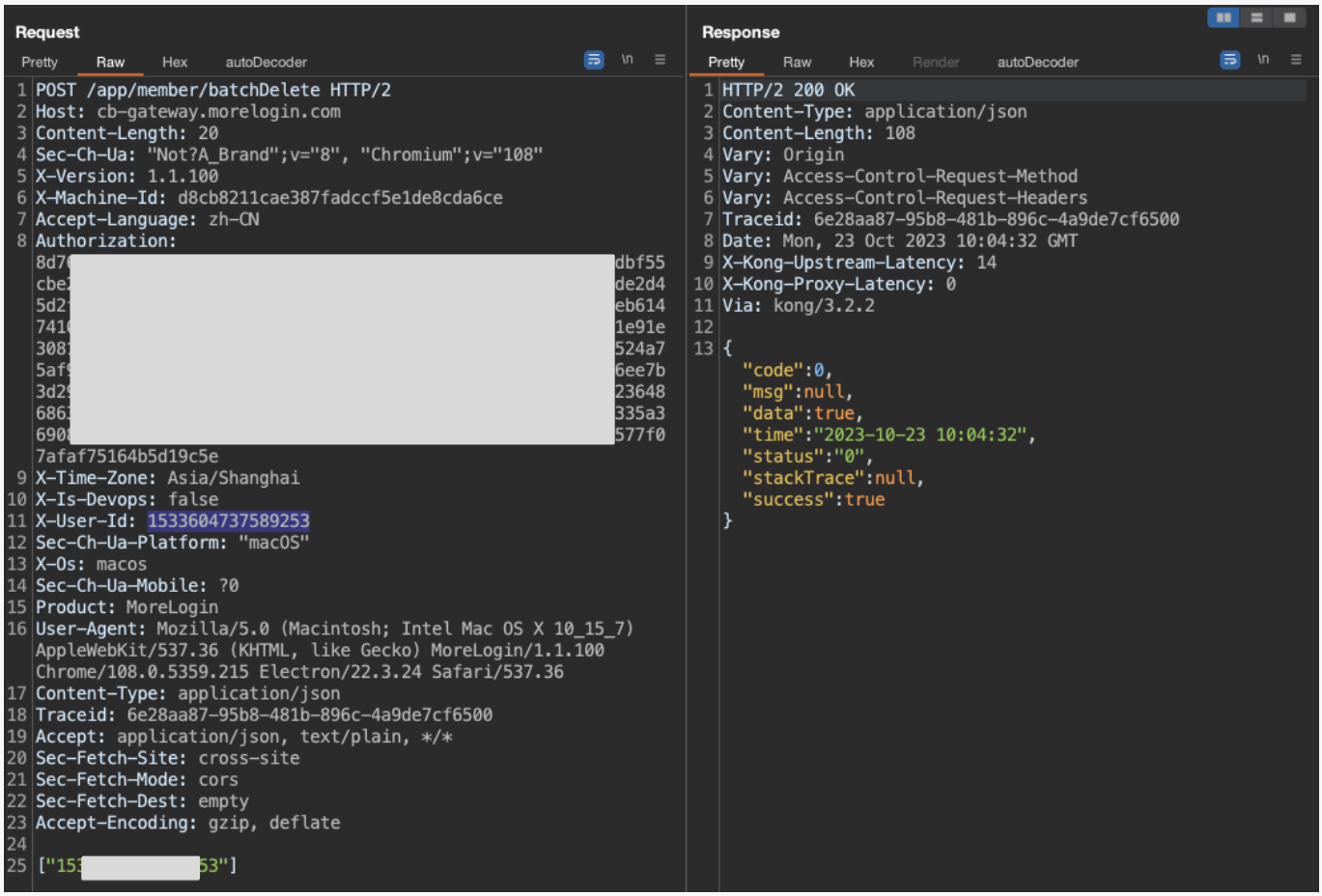
[N15] [Suggestion] Unauthorized Deletion of Boss-level Accounts

Category: Business security audit

Content

The member deletion API uses the ID of the member as a parameter.

API Endpoint: https://cb-gateway.morelogin.com/app/member/batchDelete.



Deletion API will delete all information associated with the account if the parameter specifies a Boss-level account.

Deleting one's own account does not require a second confirmation from the user. If the account still has remaining balance and environments but no reminders, it can result in losses.

Solution

It is recommended to restrict the deletion of Boss-level accounts.

Status

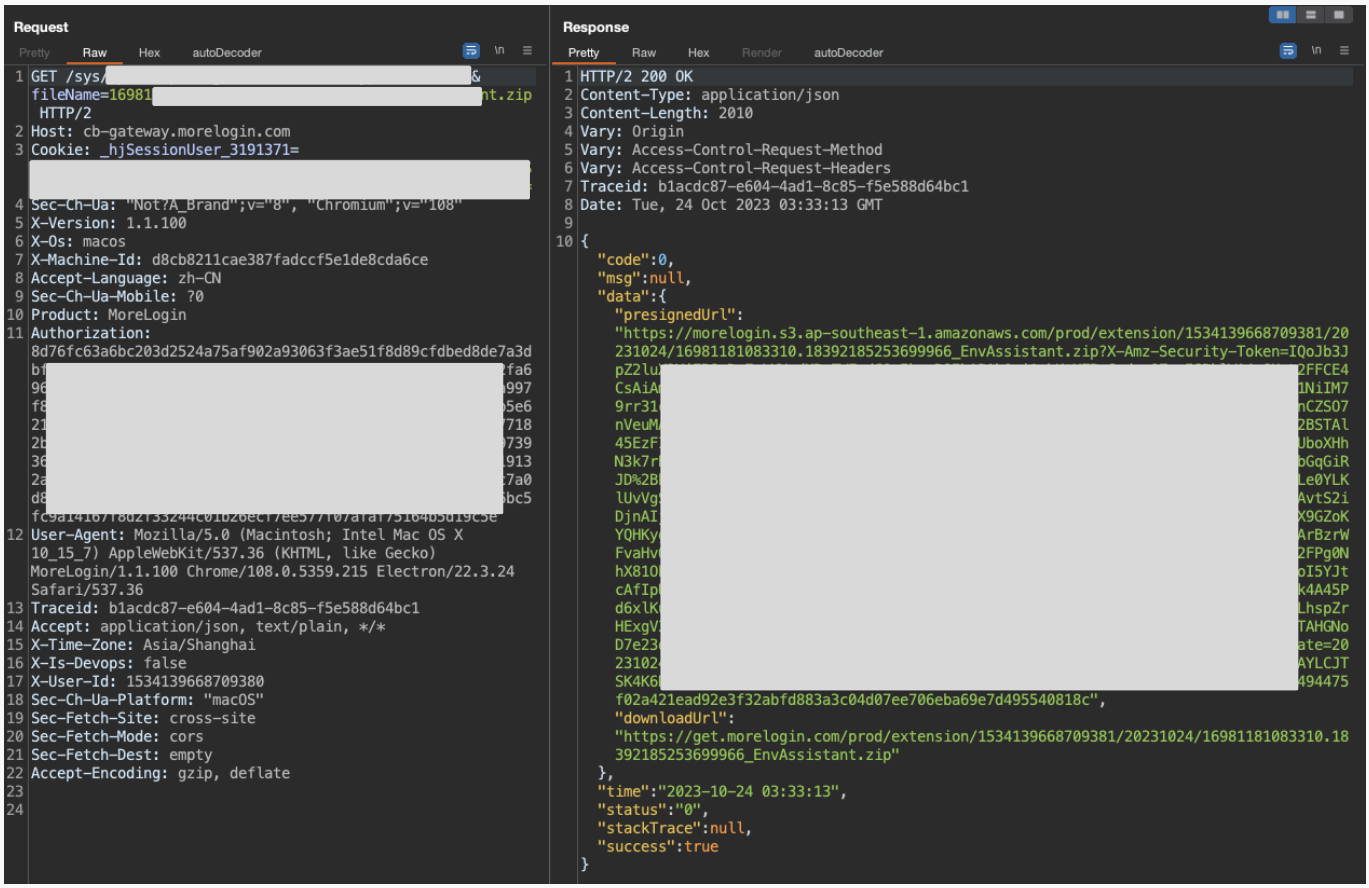
Fixed

[N16] [Medium] Unexpected file type upload issue

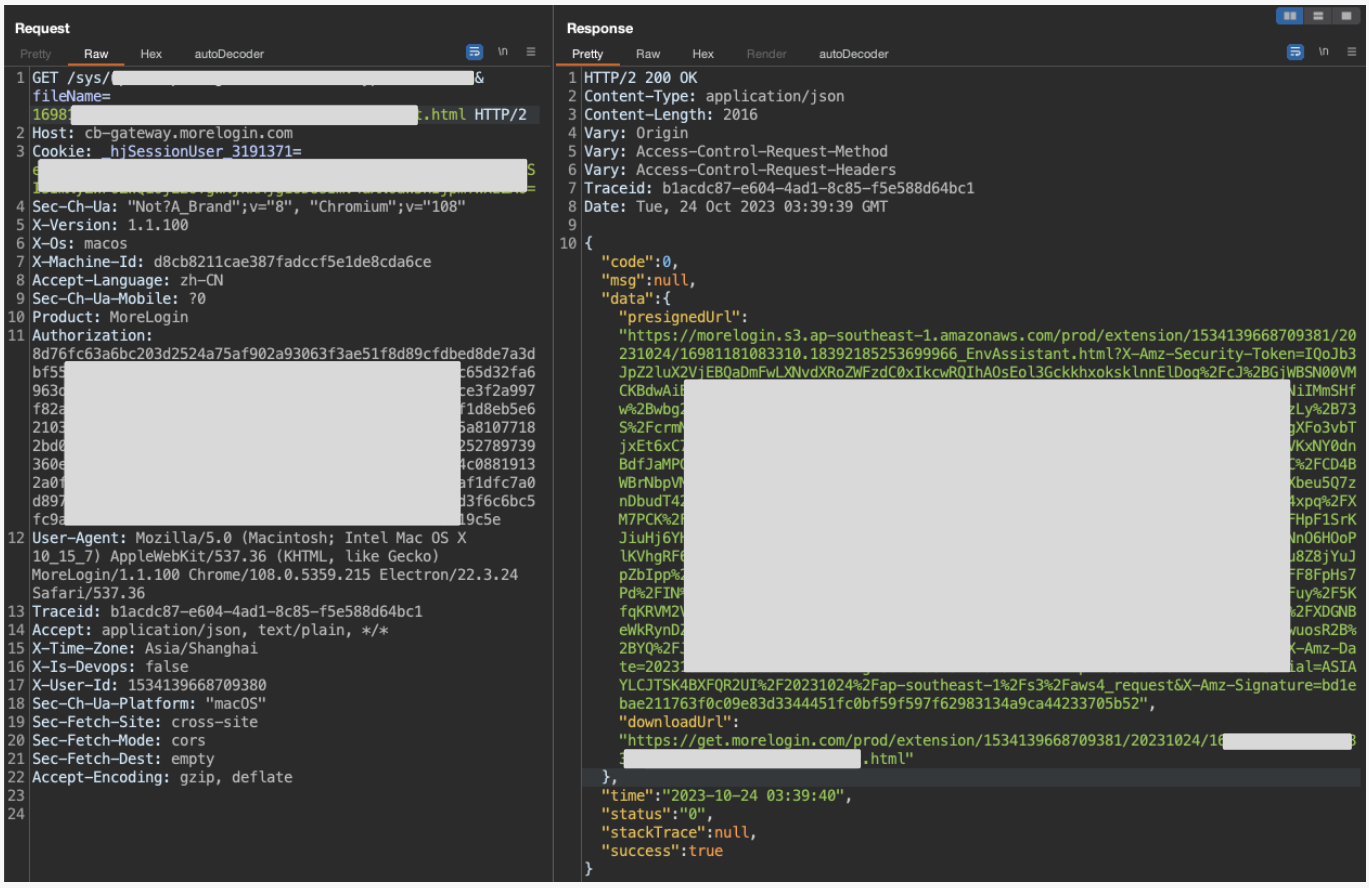
Category: Unexpected file type upload test

Content

The plugin uploads the filename to S3 to generate a link.

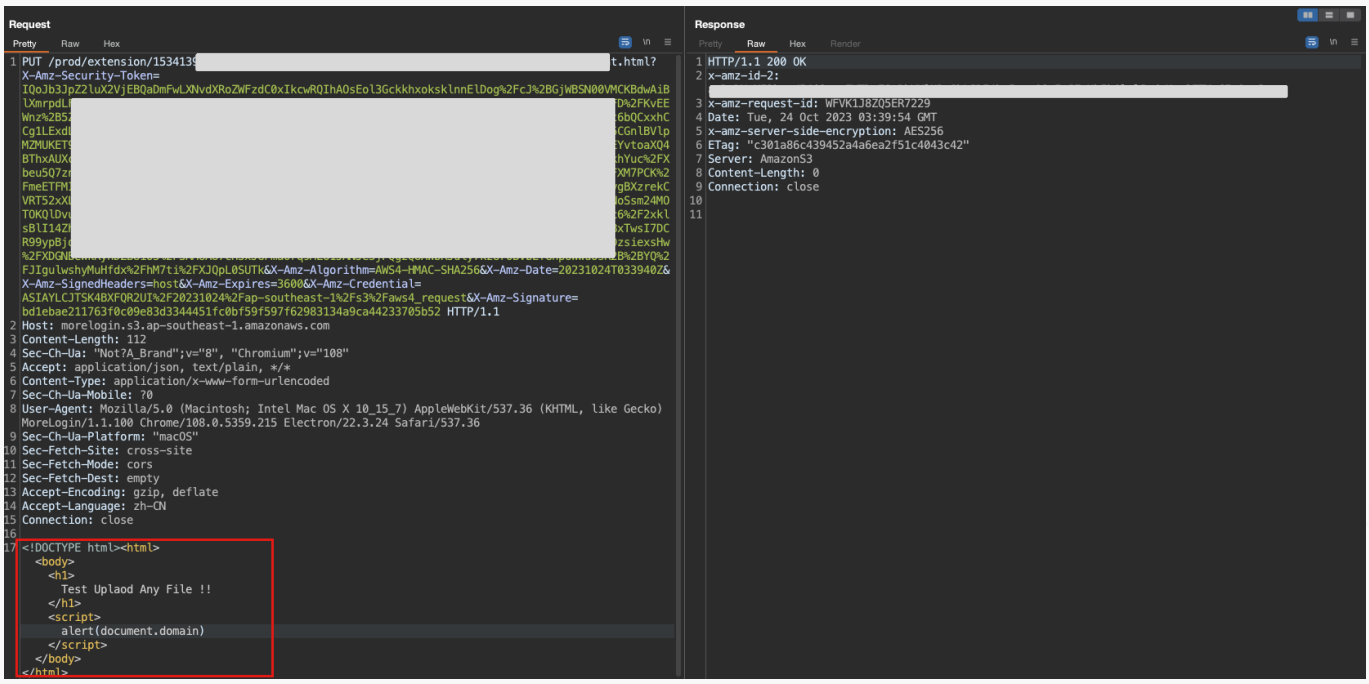


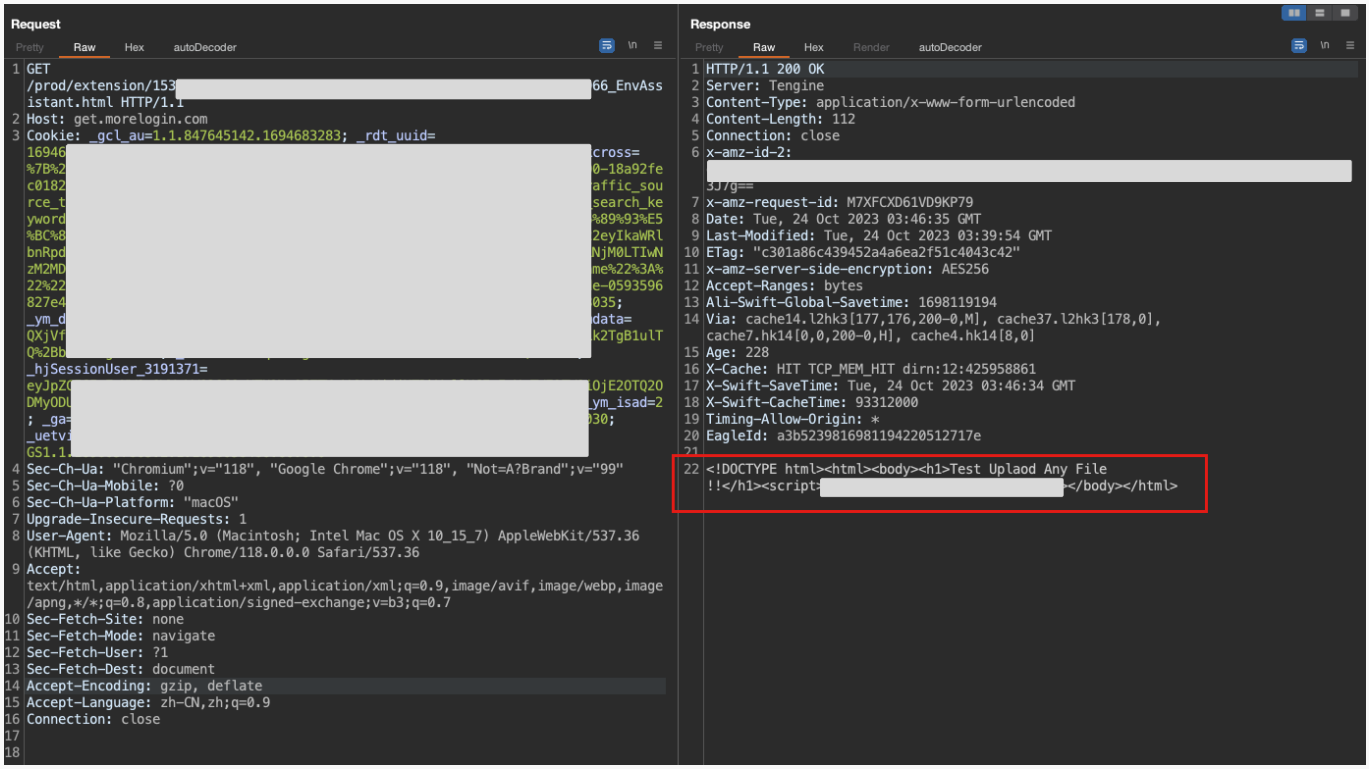
The file content is uploaded using the PUT method. The upload functionality does not restrict file types, allowing the upload of any file, such as uploading an HTML file to the morelogin.com domain.



Following that, the file content will be PUT to the following link:

https://get.morelogin.com/prod/extension/1534139668709381/20231024/





File uploads allow for the upload of files of any type and with any file extension.

Solution

It is recommended to add server-side validation for uploaded file types, enforce strict limitations, and rename the uploaded file names.

Status

Fixed

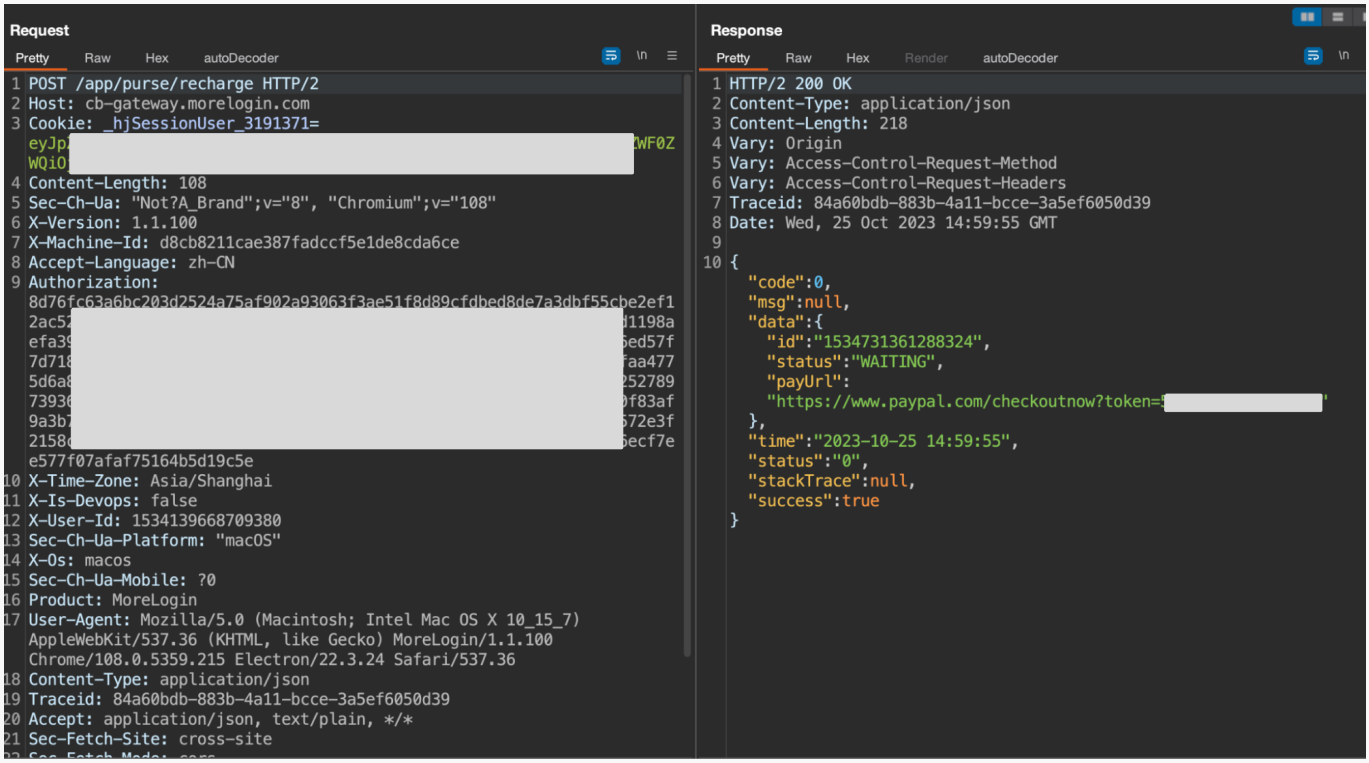
[N17] [Low] Lack of Minimum Recharge Amount Restriction on the Server

Category: Business security audit

Content

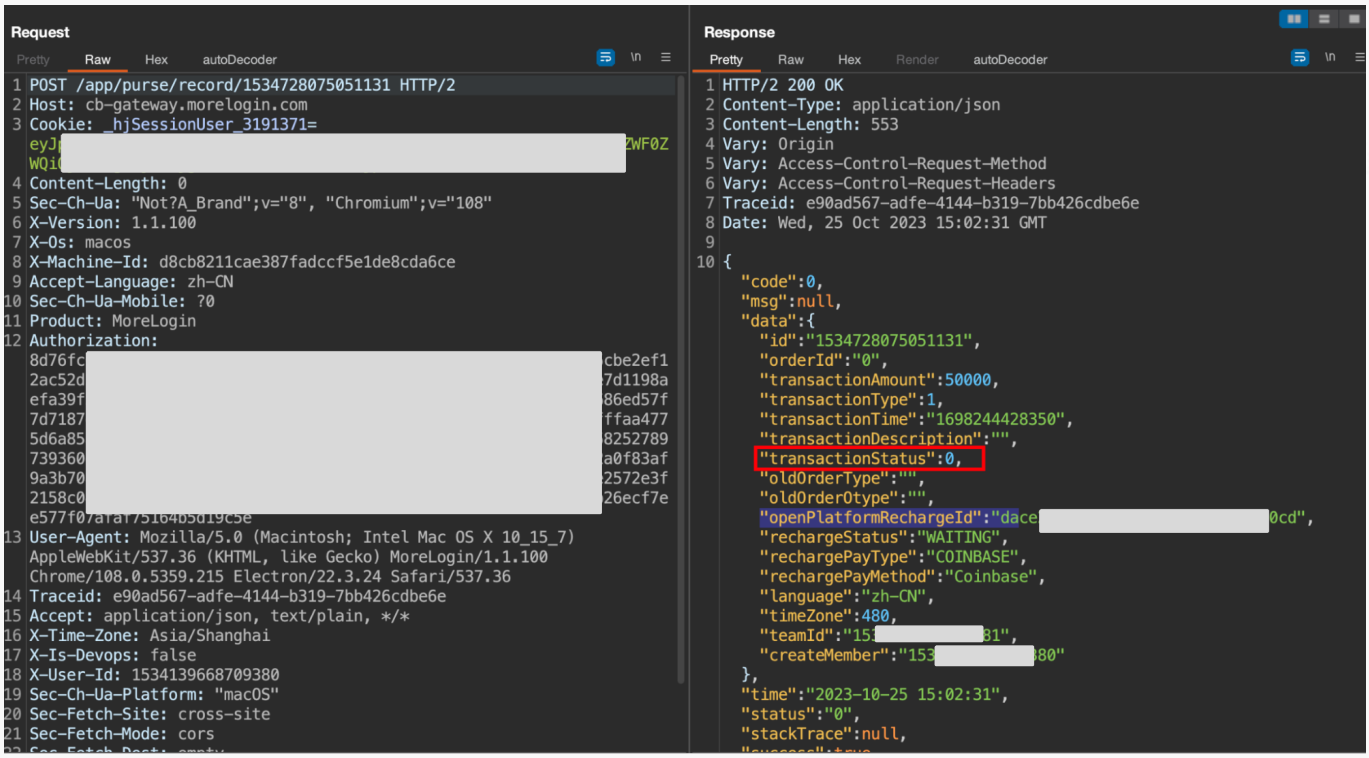
The recharge logic is performed by invoking a third-party page, and the server-side is responsible for validating the recharge logic.

The API endpoint "https://cb-gateway.morelogin.com/app/purse/recharge" is used to retrieve the third-party recharge page.

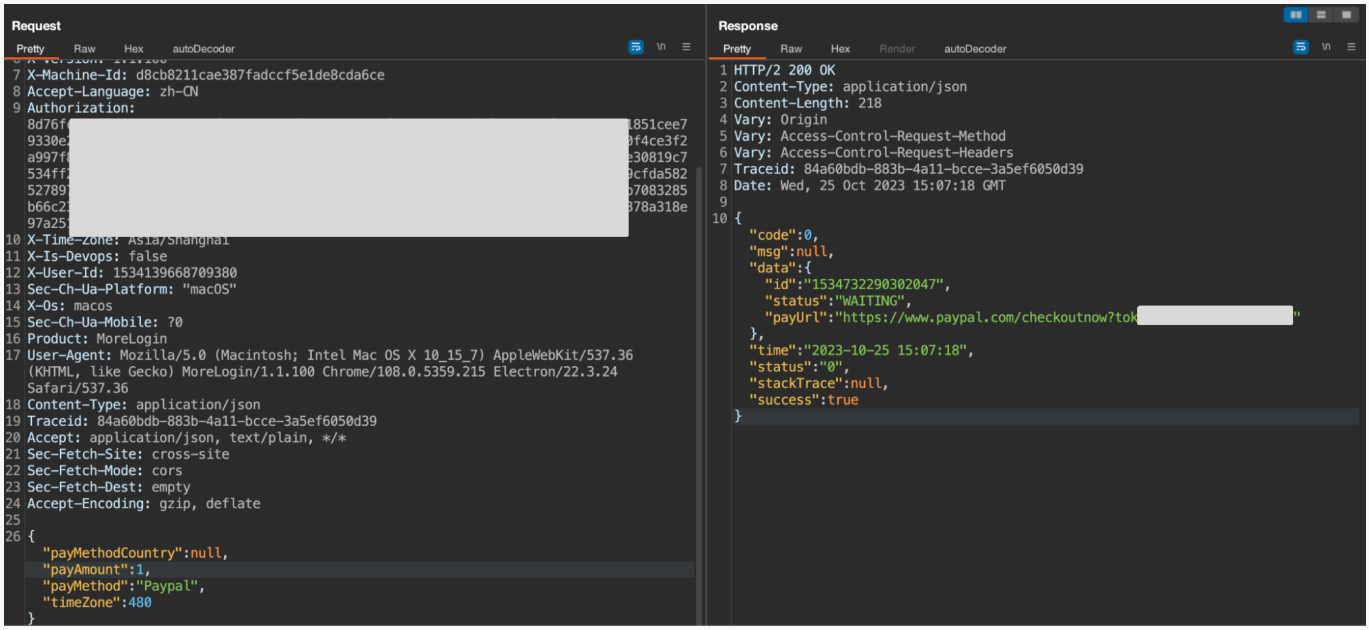


Then, the success of the recharge is determined based on the ID.

API Endpoint: https://cb-gateway.morelogin.com/app/purse/record/1534728075051131.



The client displays a minimum recharge amount of 100, but in reality, recharge orders can be placed for amounts lower than this threshold.



Solution

It is recommended to implement server-side validation for the minimum recharge amount.

Status

Fixed

[N18] [Suggestion] Source Map Leads to Source Code Leakage

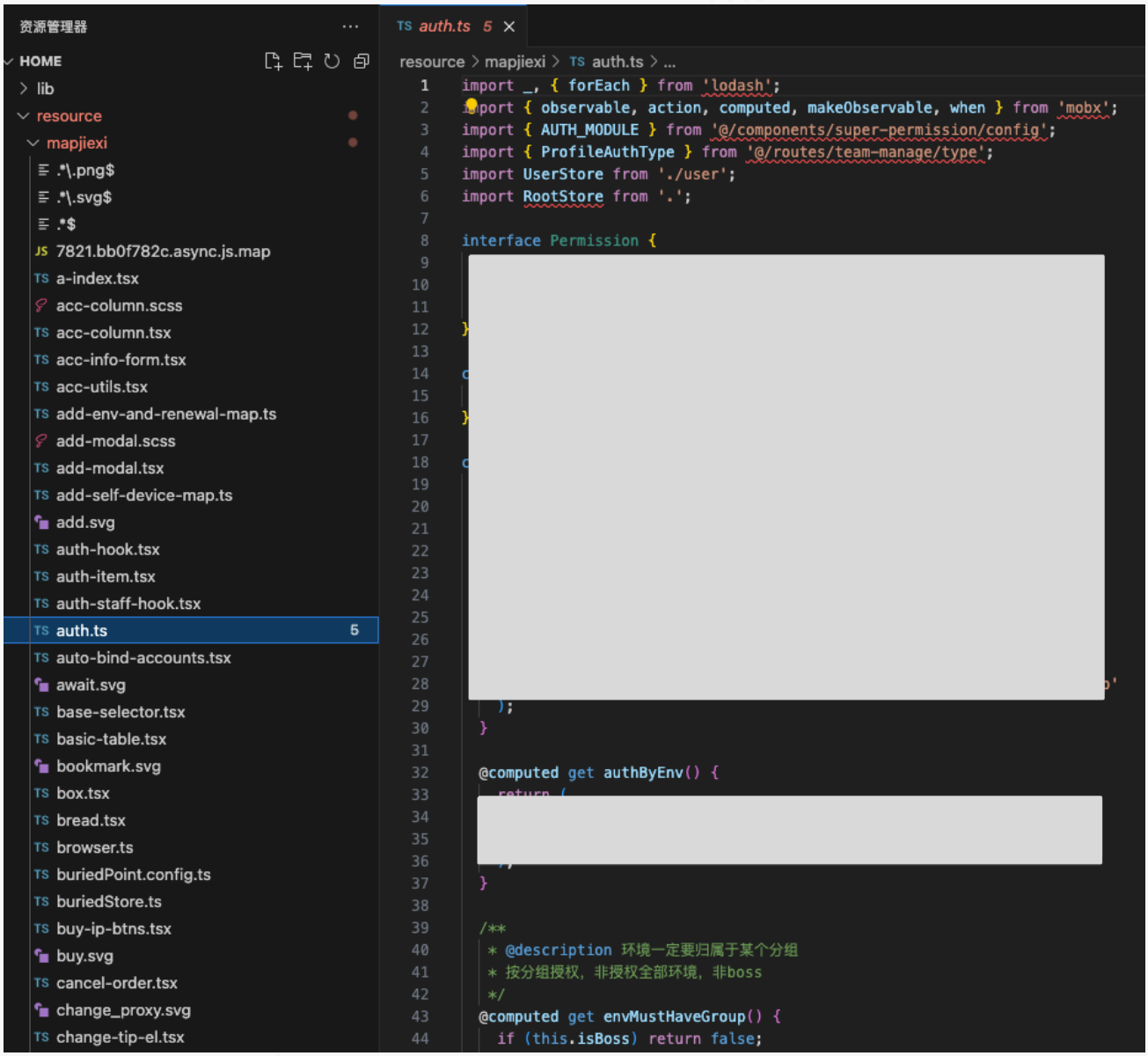
Category: Code decompilation detection

Content

Source Map Files in MoreLogin Software Packages Lead to Decompilation of Unobfuscated Source Code, including TypeScript.

```
p__loginPage__retrieve-password__reset-success.3f884416.async.js
p__loginPage__retrieve-password__reset-success.3f884416.async.js.map
p__loginPage__retrieve-password__reset-success.414ceb3b.chunk.css
p__loginPage__retrieve-password__reset-success.414ceb3b.chunk.css.map
p__message-center__index.35c1bd3b.async.js
p__message-center__index.35c1bd3b.async.js.map
p__message-center__index.fc049341.chunk.css
p__message-center__index.fc049341.chunk.css.map
p__oper-log__index.0613d115.async.js
p__oper-log__index.0613d115.async.js.map
p__oper-log__index.38572796.chunk.css
p__oper-log__index.38572796.chunk.css.map
p__package-upgrade__index.170f43de.async.js
p__package-upgrade__index.170f43de.async.js.map
p__package-upgrade__index.a1aa3c50.chunk.css
p__package-upgrade__index.a1aa3c50.chunk.css.map
p__resource-center__index.56f6a29a.async.js
p__resource-center__index.56f6a29a.async.js.map
p__resource-center__index.8266996f.chunk.css
p__resource-center__index.8266996f.chunk.css.map
p__software-settings__index.244d64dd.async.js
p__software-settings__index.244d64dd.async.js.map
p__software-settings__index.c36e4869.chunk.css
p__software-settings__index.c36e4869.chunk.css.map
p__team-manage__index.8107720f.chunk.css
p__team-manage__index.8107720f.chunk.css.map
p__team-manage__index.f32fb017.async.js
p__team-manage__index.f32fb017.async.js.map
```

Obtaining the source code by parsing ".map" files.



The software contains Source Map files that haven't been removed, allowing the unobfuscated source code files to be parsed and viewed.

Solution

In production environments, such as software installation packages, it is important to remove Source Map files.

Status

Fixed

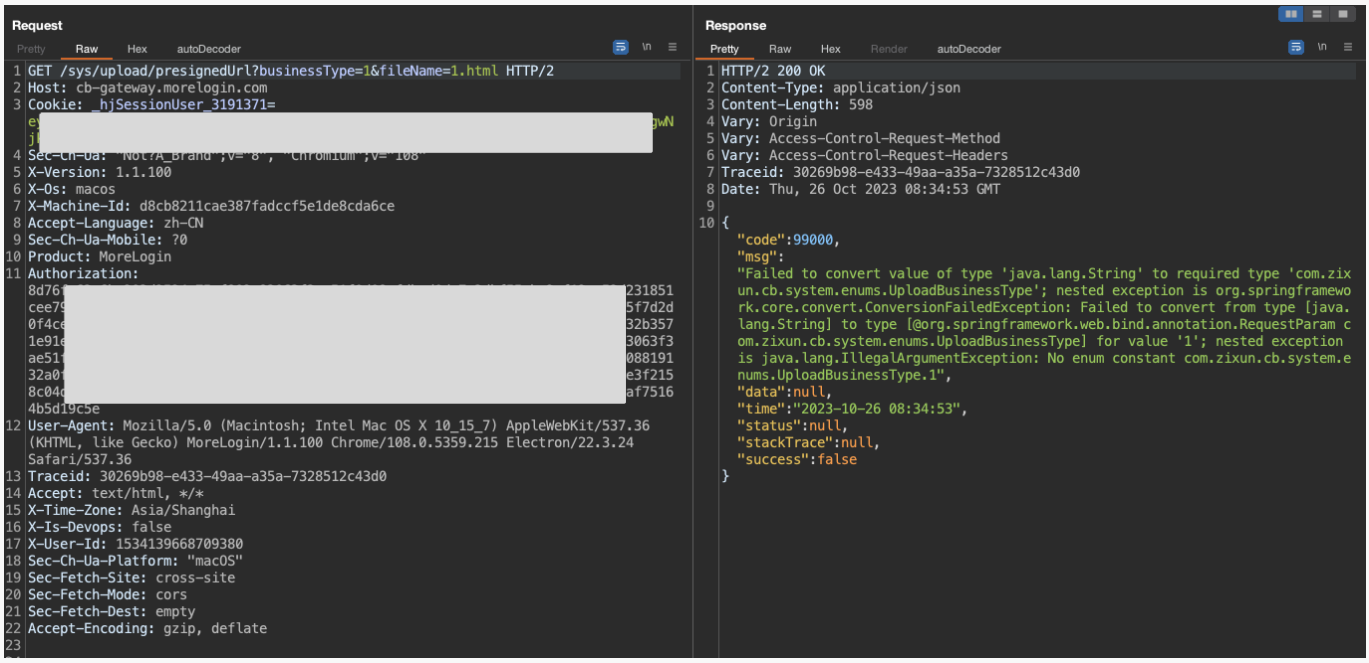
[N19] [Suggestion] Leakage of Sensitive Information in Error Messages

Category: Interface security audit

Content

Lack of Consistent Error Handling on the Server Side Leads to Leakage of Sensitive Information.

For example, the following error message reveals that the server is developed using Java language and exposes the development components.



Solution

It is recommended to standardize the output of error messages for consistent handling.

Status

Fixed

[N20] [Suggestion] Lack of File Integrity Verification in MoreLogin

Category: Integrity test

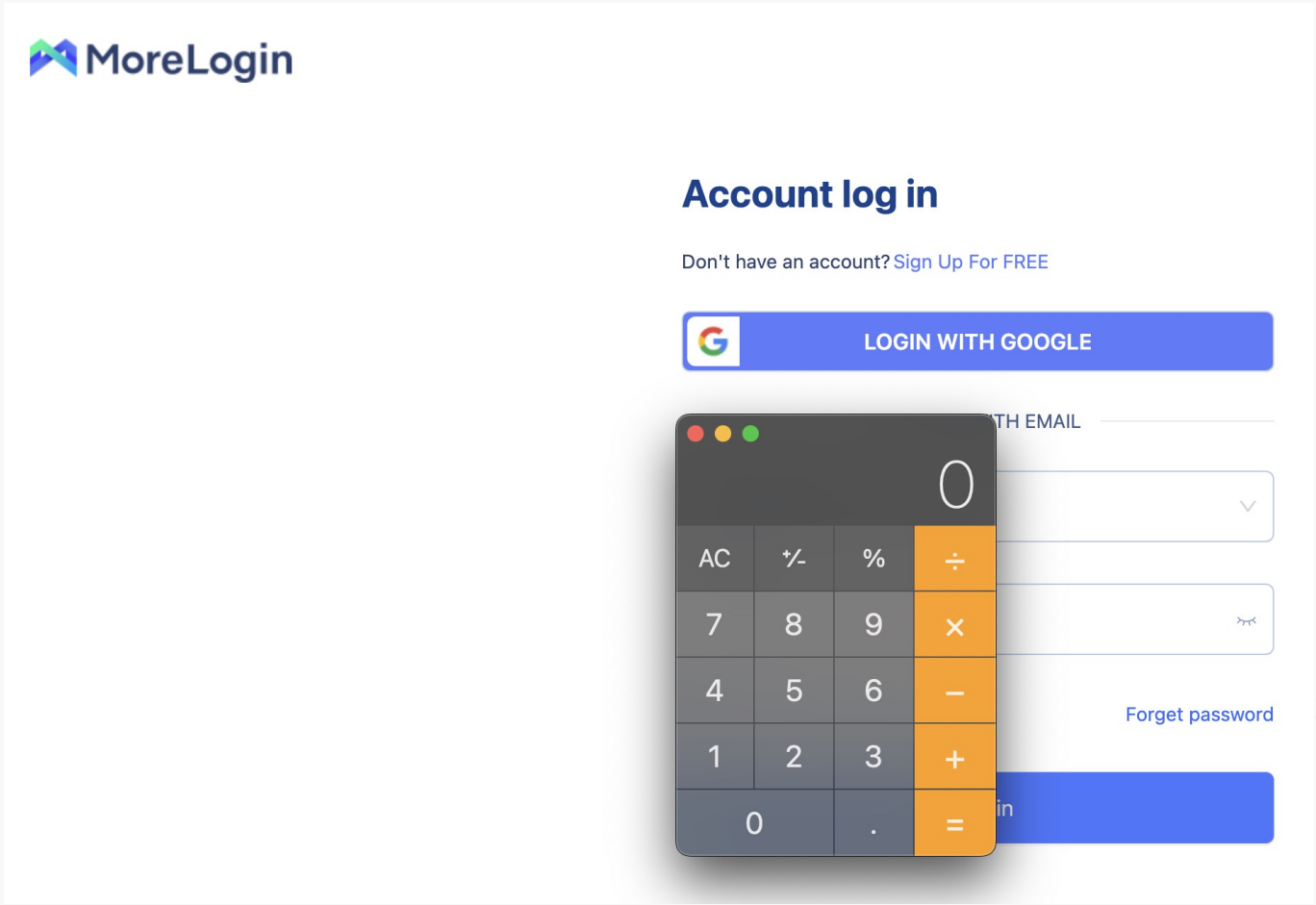
Content

MoreLogin is developed using Electron and does not enable ASAR integrity check, which means it cannot ensure that the app.asar file is generated by the asar npm package that supports ASAR integrity.

It has been observed that modifying the contents of "MoreLogin AirDrop.app" on MoreLogin, and then re-signing and opening it, does not result in any abnormal behavior. The modified program can still be opened.

For example, adding the following code to the resources file in the app.asar file will result in the execution of the code (the example below opens the macOS calculator):

```
require('child_process').execSync('open -a /System/Applications/Calculator.app');
```



Therefore, the modified "MoreLogin AirDrop.app" could potentially be used for malicious phishing.

Solution

It is recommended to Implement Program File Integrity Verification.

Status

Confirmed

[N21] [Low] Cross Site Scripting (XSS) issue

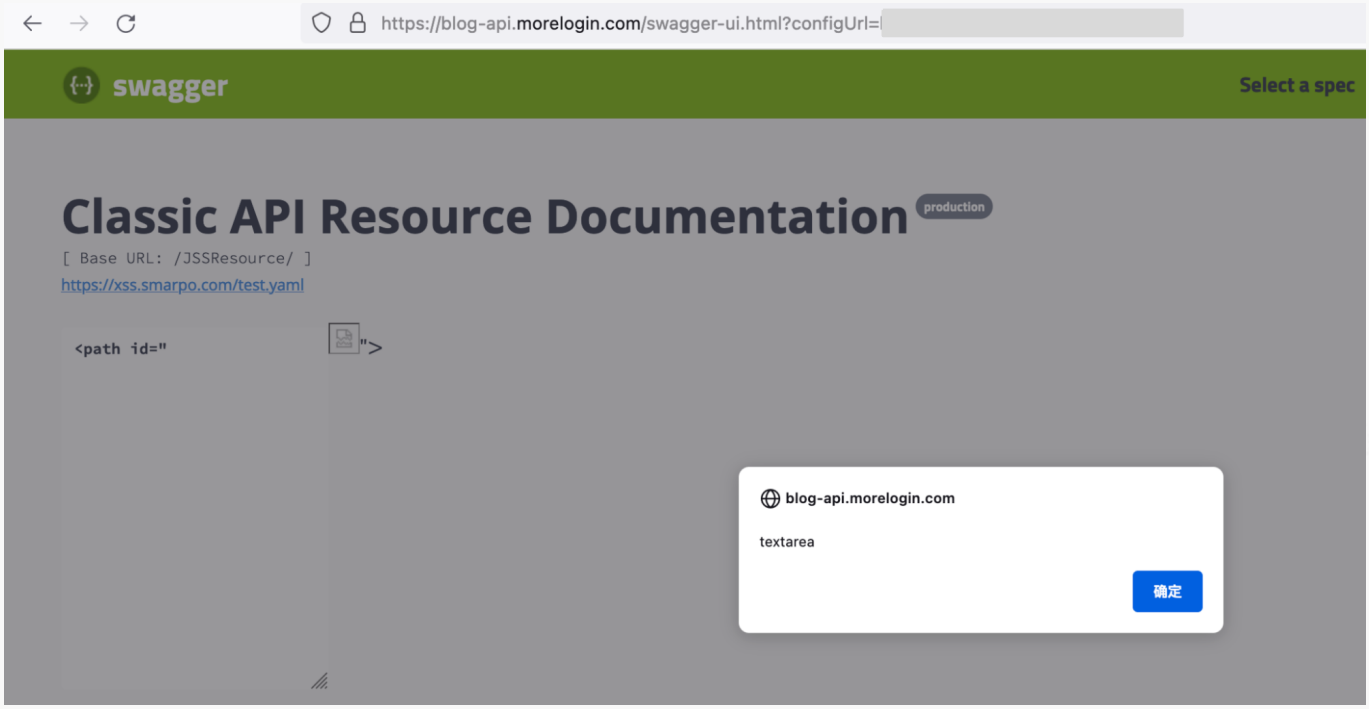
Category: Cross Site Scripting (XSS) test

Content

The Swagger-UI component of the subdomain "blog-api.morelogin.com" has a cross-site scripting vulnerability.

Test Poc:

```
https://blog-api.morelogin.com/swagger-ui.html?
configUrl=https://xss
```



Solution

It is recommended to remove the Swagger-UI component if it is not needed for non-production purposes. If the business requires it, upgrading Swagger-UI to the latest version is recommended.

Status

Fixed

[N22] [Suggestion] Information Leakage in Spring Boot

Category: Application platform configuration management test

Content

Sensitive Path Exposure Detected in Spring Boot on URL https://cb-gateway.morelogin.com.

Following sensitive paths were identified during the reconnaissance:

```
actuator
actuator/beans
actuator/conditions
actuator/health
actuator/env
actuator/info
actuator/heapdump
actuator/metrics
actuator/mappings
actuator/scheduledtasks
```

```
actuator/loggers
actuator/configprops
```

Solution

It is recommended to strictly block external access to the relevant paths.

Status

Fixed

4 Audit Result

Audit Number	Audit Team	Audit Date	Audit Result
0X002310250001	SlowMist Security Team	2023.10.19 - 2023.10.25	Passed

Summary conclusion: The SlowMist security team use a manual and SlowMist team's analysis tool to audit the project, during the audit work we found 3 high risk, 1 medium risk, 4 low risk, 14 suggestion vulnerabilities. And 2 suggestions were Acknowledged, 1 suggestion were confirmed, all others vulnerabilities were Fixed. We extend our gratitude for MoreLogin team recognition of SlowMist and hard work and support of relevant staff.

Remarks: MoreLogin team provides their server-side encryption scheme to illustrate their security practices: https://get.morelogin.com/doc/MoreLogin_Security_Document_en.pdf

5 Statement

SlowMist issues this report with reference to the facts that have occurred or existed before the issuance of this report, and only assumes corresponding responsibility based on these.

For the facts that occurred or existed after the issuance, SlowMist is not able to judge the security status of this project, and is not responsible for them. The security audit analysis and other contents of this report are based on the documents and materials provided to SlowMist by the information provider till the date of the insurance report (referred to as "provided information"). SlowMist assumes: The information provided is not missing, tampered with, deleted or concealed. If the information provided is missing, tampered with, deleted, concealed, or inconsistent with the actual situation, the SlowMist shall not be liable for any loss or adverse effect resulting therefrom. SlowMist only conducts the agreed security audit on the security situation of the project and issues this report. SlowMist is not responsible for the background and other conditions of the project.



Official Website

www.slowmist.com



E-mail

team@slowmist.com



Twitter

@SlowMist_Team



Github

https://github.com/slowmist